Universidad Mariano Gálvez de Guatemala

Seguridad y Auditoría de Sistemas

Política Integral de Seguridad de la Información, Implementación y Auditoría del Gestor Clínica Duality

Integrantes

Julián Hernández Girón — 0900-23-25542

Carlos Augusto Calderón Estrada — 0900-24-8040

Federico Guillermo Iturbide Cerna — 0900-23-25655

Guatemala, 2026.

Índice general

1 Introducción 7

2 Objetivos 7

Objetivo general 7

Objetivos específicos 7

3 Alcance y criterios de interpretación 8

4 Metodología 9

5 Marco de referencia 9

6 Etapa I Política Integral General 10

Objetivo y alcance de la política 10

Principios de seguridad de la información 10

Aplicación del marco NIST CSF 2 0 10

Gobierno y responsabilidades 11

Gestión de activos 11

Clasificación y protección de la información 12

Control de identidades y accesos 12

Seguridad de aplicaciones y bases de datos 12

Seguridad de infraestructura y redes 13

Seguridad cloud y DevSecOps 13

Gestión de vulnerabilidades 13

Gestión de incidentes 13

Gestión de cambios 14

Respaldos y continuidad 14

Seguridad de terceros 14

Cumplimiento excepciones y mejora continua 15

7 Etapa II Aplicación en Clínica Duality 16
Descripción de la empresa y contexto 16
Procesos críticos y descripción funcional 16
Arquitectura tecnológica real 16
Inventario de activos y clasificación de información 17
Amenazas y evaluación de probabilidad e impacto 19
Tratamiento y riesgos residuales 21
Matriz de accesos y condiciones de autorización 22
Requisitos de seguridad trazables 22
Adaptación de la política y selección de controles 23
Implementaciones realizadas y registro de cambios 26
Seguridad en diagramas UML 26
Seguridad de aplicaciones 30
Seguridad de PostgreSQL e integridad transaccional 31
Seguridad de Redis y gestión de sesiones 31
Seguridad de contenedores y redes 31
Seguridad DevSecOps y repositorio 32
Vulnerabilidades de dependencias y análisis estático 32
Proveedores cloud y responsabilidad compartida 33
Gestión de incidentes y continuidad 34
Pruebas y criterios de validación 35
Evidencias principales 37
Evidencias de logs y reportes sin captura 41
Riesgos residuales y plan de mejora 41
8 Análisis de resultados 43
9 Conclusiones 43

10 Recomendaciones 44

11 Referencias bibliográficas 45

12 Anexos 47

Anexo A Matriz completa de accesos 47

Anexo B Trazabilidad detallada de controles 50

Anexo C Catálogo de evidencias y procedencia 59

Anexo D Casos de prueba ejecutados y omitidos 63

Anexo E Integridad del expediente y evidencia no reproducida 67

Índice de figuras

Figura 1. Arquitectura observada de la solución 17
Figura 2. Componentes y verificaciones compartidas de seguridad 27
Figura 3. Despliegue local y límites de confianza 28
Figura 4. Casos de uso y control de acceso por rol 29
Figura 5. Secuencia de validación de una sesión protegida 30
Figura 6. Reporte final de pruebas locales 38
Figura 7. Pruebas reales de integridad concurrencia y restauración 39
Figura 8. Formulario local sin credenciales precargadas 40

Índice de tablas

Tabla 1. Niveles de evidencia utilizados.....8
Tabla 2. Estados oficiales para evaluar controles.....9
Tabla 3. Funciones del marco y aplicación propuesta.....11
Tabla 4. Procesos soportados y efectos de una interrupción.....16
Tabla 5. Inventario lógico de activos.....18
Tabla 6. Clasificación y condiciones de tratamiento.....19
Tabla 7. Matriz de riesgos y valoración inicial.....20
Tabla 8. Tratamiento y residual preliminar.....21
Tabla 9. Resumen de permisos por rol.....22
Tabla 10. Requisitos conservados del documento preliminar.....22
Tabla 11. Adaptación de dominios de política.....23
Tabla 12. Matriz de controles seleccionados y estado.....24
Tabla 13. Bitácora resumida de cambios de seguridad.....26
Tabla 14. Avisos de dependencias registrados.....32
Tabla 15. Proveedores y dependencias documentadas.....33
Tabla 16. Escenarios de incidente y criterios de recuperación.....34
Tabla 17. Decisiones de continuidad pendientes de aprobación.....35
Tabla 18. Plan y resultados de pruebas controladas.....36
Tabla 19. Resultados de las ejecuciones y análisis.....37
Tabla 20. Extractos verificables de resultados.....41
Tabla 21. Plan de mejora y criterios de cierre.....42
Tabla 22. Accesos por endpoint observado.....47
Tabla 23. Casos registrados en JUnit final.....63

1 Introducción

El Gestor Clínica Duality dispone de controles de seguridad que pueden demostrarse en un laboratorio local, pero conserva riesgos técnicos y decisiones organizacionales sin resolver. La revisión del código, las pruebas y los artefactos registró 69 pruebas aprobadas y 6 omitidas, además de 40 controles: 8 implementados y validados en su alcance local, 18 parcialmente implementados y 14 propuestos. Estos resultados no equivalen al cumplimiento total de la guía ni a la validación de un ambiente de producción [E01; T01].

El informe amplía el documento preliminar del equipo y organiza el trabajo en las dos etapas exigidas por el curso. La primera establece una política integral general; la segunda adapta sus reglas a los activos y riesgos observados en Duality, describe las implementaciones y relaciona cada resultado con evidencia verificable. Se conserva la diferencia entre una regla propuesta, un control presente en el código y un control cuyo funcionamiento ha sido probado [D1, pp. 1–4; D2].

La autoría académica corresponde a los integrantes indicados en la portada. La ejecución técnica y la consolidación documental utilizaron asistencia de Codex, con revisión humana pendiente. La propietaria y los responsables de la clínica deberán aprobar las decisiones de negocio, la política, los accesos, la continuidad y la aceptación de riesgos antes de su adopción operativa. No se atribuyen entrevistas, firmas, aprobaciones o despliegues que no consten en las fuentes.

2 Objetivos

Objetivo general

Diseñar y adaptar una política integral de seguridad de la información al Gestor Clínica Duality, evaluando los riesgos de su arquitectura y documentando controles, pruebas, evidencias y actividades de mejora que permitan revisar su eficacia y sus limitaciones.

Objetivos específicos

- Identificar los activos, procesos, identidades y dependencias visibles en el sistema y distinguirlos de la infraestructura organizacional no confirmada.
- Evaluar amenazas y vulnerabilidades mediante una escala explícita de probabilidad e impacto y asociar el tratamiento con responsables propuestos.

- Describir las correcciones autorizadas y contrastarlas con pruebas positivas, negativas, de integridad, concurrencia y restauración controlada.
- Relacionar requisitos, controles, pruebas y evidencias conservando los estados oficiales de la guía.
- Definir procedimientos de incidentes, cambios, terceros y continuidad que la clínica pueda revisar y aprobar con información real.

3 Alcance y criterios de interpretación

El alcance técnico comprende los servicios auth, catalogo, pedidos y pagos; el código común; el frontend; Nginx; los scripts y objetos PostgreSQL; Redis; Docker Compose; dependencias y definiciones de GitHub Actions, Jenkins y Azure Pipelines. Los módulos funcionales incluyen pacientes, usuarios, productos, servicios, inventario, servicios realizados, ventas, pagos y reportes. El alcance administrativo descrito en el preliminar excluye diagnóstico y receta electrónica; debe confirmarse con la clínica [D2, p. 2; T02].

La línea base corresponde al commit f5351224bd8910be20e19db743f6a7b1b7921401. Las mejoras permanecen en el árbol local de la rama auditoria-ciberseguridad, sin commit que las consolide, push o pull request. Los hashes de fuentes en ejecuciones.json identifican el código probado. El levantamiento físico, los contratos cloud, las configuraciones de producción, el SLA y la aceptación de usuarios no se verificaron. AWS permanece como previsión documental, sin recursos desplegados acreditados [E07; E11].

Tabla 1. Niveles de evidencia utilizados

Ámbito	Qué acredita	Límite
Validación local	Funciones criptográficas, validación JWT, decisiones HTTP con dobles de Redis y BD.	No demuestra operación de esos servicios ni integración completa.
Integración SQL de laboratorio	Objetos reales de PostgreSQL 16.15, dos clientes concurrentes y restauración a base separada.	Datos sintéticos; no producción ni recuperación integral del servicio.
Evidencia remota histórica	Corrida de GitHub Actions del commit base y lectura de configuración remota.	No acredita aplicación desplegada ni prueba los cambios locales.
Validación desplegada	No se ejecutó para los cambios locales.	Requiere staging autorizado y pruebas del servicio completo.

4 Metodología

Se revisaron nuevamente los dos PDF académicos, los archivos técnicos de seguridad, el código relevante y las fuentes originales de evidencia. La evaluación siguió la secuencia de identificar, analizar, evaluar, tratar, implementar, probar, evidenciar y mejorar. Las tablas se contrastaron con controles.json; los conteos se recalcularon desde JUnit XML y los registros de dependencias se distinguieron de los identificadores únicos de aviso [D1, pp. 2–3; T01; E01; E08].

La auditoría técnica comenzó en modo de solo lectura y luego aplicó cambios de bajo riesgo dentro del alcance autorizado. Las tres modificaciones de autenticación recibieron autorización expresa. Las pruebas de SQL utilizaron exclusivamente un contenedor identificado, etiquetado y aislado; posteriormente se retiró con su volumen anónimo. Esta elaboración académica no modifica código, pipelines, datos ni infraestructura [T07; E03; E07].

Tabla 2. Estados oficiales para evaluar controles

Estado	Criterio aplicado
Implementado y validado	Existe implementación, prueba ejecutada y evidencia suficiente para el alcance expresamente delimitado.
Parcialmente implementado	Existe implementación, pero faltan integración, cobertura, evidencia, configuración o adopción operativa.
Propuesto	No se ha implementado el control o no existe la aprobación, información o acceso necesario; se documenta justificación y residual.

5 Marco de referencia

NIST CSF 2.0 organiza los resultados de ciberseguridad en las funciones Govern, Identify, Protect, Detect, Respond y Recover. Se propone como estructura de gobierno y seguimiento para el proyecto; no se afirma que la clínica haya adoptado formalmente el marco ni alcanzado una certificación. OWASP ASVS se utiliza como apoyo para redactar requisitos verificables de aplicaciones y orientar pruebas, sin atribuir un nivel completo de conformidad [R1; R2].

La guía del curso define las obligaciones académicas. Los requisitos RS-01–RS-10 se vinculan con C01–C40. La documentación de PostgreSQL, Redis, Docker y GitHub permite interpretar mecanismos que deben contrastarse con el código y la evidencia [D1; D2; R3–R6].

6 Etapa I Política Integral General

La siguiente política se presenta para aprobación organizacional. Su estado es Propuesto. La existencia de controles técnicos locales no sustituye la aprobación de la política ni la asignación de autoridades y recursos. Las responsabilidades se expresan por función, sin nombres o fechas de vigencia inventados [T03; C32–C39].

Objetivo y alcance de la política

La organización deberá proteger la confidencialidad, integridad, disponibilidad y trazabilidad de la información que sostiene sus procesos. La política deberá abarcar personas con acceso, datos, aplicaciones, bases, equipos, redes, proveedores y cambios durante el desarrollo y la operación. Se aplicará a los activos confirmados y a las dependencias necesarias; toda exclusión deberá justificar el riesgo y su tratamiento.

La autoridad de negocio deberá aprobar el alcance, la versión y la vigencia de la política, así como designar a sus responsables. La aplicación de reglas sobre datos de pacientes y finanzas deberá considerar la finalidad autorizada, los permisos y los plazos de conservación que se determinen con información real.

Principios de seguridad de la información

Se aplicará mínimo privilegio y necesidad de conocer: cada identidad accederá a las funciones y datos indispensables para su responsabilidad. Las cuentas deberán ser individuales y las tareas administrativas deberán distinguirse de la operación cotidiana. La separación de funciones se adaptará al tamaño de la organización sin eliminar la revisión de acciones críticas.

Los controles deberán ser explícitos, comprobables y proporcionales al riesgo. La protección de datos deberá integrar validación de entradas, reducción de exposición, conservación de integridad y capacidad de recuperación. Las conclusiones dependerán de evidencia auténtica; una prueba omitida o una configuración propuesta no podrá presentarse como cumplimiento probado.

Aplicación del marco NIST CSF 2 0

El marco se utilizará para ordenar objetivos y responsables, identificar activos y riesgos, seleccionar protecciones, detectar desviaciones, responder y recuperar la operación. Su función en este informe es

metodológica: no prescribe incorporar tecnologías sin una justificación y no reemplaza la evidencia técnica o la decisión de la propietaria [R1].

Tabla 3. Funciones del marco y aplicación propuesta

Función	Aplicación en el proyecto
Govern	Autoridades, política, responsabilidades y excepciones.
Identify	Activos A01–A09 y riesgos R01–R12.
Protect	Identidad, integridad, configuración y protección de datos.
Detect	Revisión de eventos y avisos; monitoreo operativo pendiente.
Respond	Escenarios y procedimiento de incidentes propuestos.
Recover	Restauración técnica y continuidad operativa por formalizar.

Gobierno y responsabilidades

La autoridad de negocio aprobará la política, los accesos relevantes, los cambios de riesgo y la aceptación de riesgos residuales. El responsable operativo validará necesidades de acceso y continuidad; administración técnica custodiará configuración, cuentas, registros y respaldos; desarrollo mantendrá revisión y pruebas. Los usuarios protegerán credenciales y reportarán anomalías.

Deberán registrarse titulares, suplentes, canales de contacto y límites de autoridad. Se propone revisar la política trimestralmente y después de incidentes o cambios relevantes, pero esta periodicidad deberá ser aprobada. La ausencia de aprobación no autoriza a considerar aceptado un riesgo.

Gestión de activos

Se mantendrá un inventario con identificador, propietario, custodio, finalidad, ubicación, clasificación, criticidad y dependencias. El inventario diferenciará activos existentes de servicios previstos y registrará las fuentes utilizadas para confirmar cada componente.

Los cambios, altas y retiros deberán actualizar el inventario y su evaluación de riesgos. La organización deberá identificar los procesos que cada activo soporta y las consecuencias de su interrupción antes de fijar objetivos de disponibilidad o recuperación.

Clasificación y protección de la información

La información se clasificará como pública, interna, confidencial o restringida según la finalidad y el impacto de exposición, alteración o pérdida. La clasificación deberá definir condiciones de almacenamiento, acceso, uso, transferencia, conservación y eliminación. Exportaciones y respaldos heredarán la sensibilidad del contenido.

Las transferencias de información confidencial o restringida utilizarán canales aprobados con protección de cifrado cuando corresponda. Los plazos y procedimientos de eliminación requerirán aprobación y revisión pertinente; no se fijan años de retención ni obligaciones legales sin verificarlas. Los datos no deberán incluirse innecesariamente en registros, presentaciones o servicios externos.

Control de identidades y accesos

El alta de una identidad requerirá una solicitud que identifique función, recursos y permisos, seguida de aprobación por la autoridad designada. Administración técnica implementará el privilegio mínimo y registrará su entrega sin conservar contraseñas en documentos. Los cambios de puesto y bajas deberán retirar accesos y comprobar el rechazo de sesiones no vigentes.

Se deberá evaluar MFA para repositorio, cloud y accesos administrativos. Las credenciales de aplicaciones deberán separarse de las cuentas de administración. La revisión de permisos deberá tener periodicidad y responsable aprobados. El acceso remoto requerirá un canal autorizado y registros, sin presumir la existencia de una VPN.

Seguridad de aplicaciones y bases de datos

La autorización se verificará en el servidor para cada operación protegida. Las sesiones deberán incluir validación de firma y vigencia, mecanismos de revocación y comprobación de identidad. Las contraseñas se almacenarán mediante un hash apropiado con salt; no se registrarán en texto claro ni se expondrán en respuestas.

Las consultas deberán parametrizar valores y limitar los identificadores dinámicos a listas controladas. Los modelos validarán entradas y las salidas deberán codificarse según su contexto. Las operaciones sensibles usarán restricciones y transacciones; los errores evitarán revelar consultas o datos internos. Las cuentas de BD tendrán permisos mínimos y las restauraciones se probarán en aislamiento.

Seguridad de infraestructura y redes

Los equipos, sistemas operativos y servicios necesarios deberán inventariarse y actualizarse. Se reducirán puertos, servicios y cuentas administrativas, y se revisará la configuración de bloqueo, administración remota y protección antimalware o EDR según el equipo real.

La arquitectura deberá definir límites de confianza, protocolos y puertos justificados. La exposición pública deberá protegerse mediante TLS y reglas de acceso verificadas. La selección de segmentación, VLAN, Wi-Fi, VPN o IDS/IPS dependerá de una amenaza identificada y de capacidad operativa comprobada; no se registrarán estas tecnologías como instaladas sin evidencia.

Seguridad cloud y DevSecOps

Los recursos cloud deberán registrar proveedor, cuenta titular, ambiente, datos, permisos, exposición y mecanismos de recuperación. La responsabilidad del proveedor se contrastará con la configuración que corresponde a la organización; un servicio gestionado no prueba que sus accesos o respaldos sean adecuados.

Los repositorios deberán proteger ramas y requerir revisión de cambios; los pipelines utilizarán permisos y secretos mínimos por ambiente. Se revisarán dependencias e imágenes y se conservarán resultados de cada etapa. Un paso requerido no deberá terminar exitosamente por omitir su función ante falta de configuración.

Gestión de vulnerabilidades

Las vulnerabilidades se registrarán con activo, condición, fuente, severidad, aplicabilidad y tratamiento. Los avisos de dependencias deberán distinguirse de una explotación demostrada y depurarse por identificador y alias antes de comunicar cantidades.

El equipo técnico deberá priorizar correcciones según riesgo, probar compatibilidad y conservar la evidencia de cierre. Las excepciones requerirán aprobación explícita y compensación documentada. La ausencia de alertas en una herramienta no constituye una garantía de seguridad del sistema.

Gestión de incidentes

Los incidentes se reportarán por un canal definido y se registrarán con hora, activo, alcance, impacto y custodio. La clasificación determinará las autoridades y acciones de contención; deberá preservarse evidencia con acceso restringido, hashes y trazabilidad de recolección.

La respuesta deberá cubrir contención, erradicación, recuperación y revisión de causa. El retorno al servicio requerirá pruebas y autorización. La comunicación a terceros y cualquier decisión jurídica deberán corresponder a responsables designados, sin difundir credenciales o datos de pacientes.

Gestión de cambios

Cada cambio relevante deberá documentar motivo, responsable, elementos afectados, impacto funcional y de seguridad, revisión, autorización cuando corresponda, pruebas, resultado y estado final. El registro deberá integrarse con historias del proyecto y control de versiones.

Los cambios de identidad, contratos API, modelos, datos persistentes e infraestructura externa deberán evaluarse antes de ejecutarse. El plan de reversión preservará integridad y evidencia; no se deberán eliminar volúmenes o restaurar bases como sustituto de una reversión de código sin evaluar el impacto.

Respaldos y continuidad

La organización deberá identificar información y procesos críticos, dependencias, responsables y alternativas de recuperación. El análisis de impacto de negocio deberá determinar RTO, tiempo objetivo de recuperación del servicio, y RPO, pérdida temporal máxima tolerable de datos.

Se aprobarán frecuencia, retención, custodia, cifrado y ubicación de las copias. La restauración se realizará en un destino aislado y deberá verificar datos, objetos, accesos y flujos de operación. Los tiempos se medirán frente a objetivos aprobados; la duración de una prueba de laboratorio no se presentará como RTO de negocio.

Seguridad de terceros

Todo proveedor deberá documentar el servicio, la información procesada, los accesos, la dependencia, el riesgo, los controles y la recuperación prevista. Los contratos y capacidades del plan deberán respaldar las afirmaciones de disponibilidad o conservación de datos.

Los accesos de soporte serán mínimos, limitados en duración y revocables. La organización deberá mantener una alternativa de recuperación compatible con sus obligaciones y evitar depender de credenciales o copias cuya custodia no esté definida.

Cumplimiento excepciones y mejora continua

Las excepciones deberán indicar control, activo, motivo, riesgo, medida compensatoria, aprobador y vencimiento. La revisión periódica contrastará resultados, incidentes y cambios con las metas acordadas, asignando responsables y evidencia de cierre.

El uso de herramientas de IA deberá proteger documentos privados, secretos y datos reales: no se remitirán a destinos externos sin autorización específica. El equipo revisará el código y los textos asistidos, conservará trazabilidad de autoría y comprobará las afirmaciones. La política requerirá revisión organizacional y asesoría pertinente antes de atribuir cumplimiento normativo.

7 Etapa II Aplicación en Clínica Duality

Descripción de la empresa y contexto

El documento preliminar identifica a Duality como una clínica de medicina estética ubicada en zona 12 de Ciudad de Guatemala, con participación de la propietaria y personal autorizado. Este contexto se conserva como antecedente declarado por el equipo y no como resultado de una entrevista o visita de esta auditoría. Deben confirmarse su organización, responsables, equipos, red, proveedores y requisitos de conservación antes de adoptar la política [D2, p. 2; T04].

Procesos críticos y descripción funcional

La solución centraliza información administrativa y relaciona los procesos de atención registrada, inventario, venta y pago. La criticidad que se indica es preliminar: deriva de consecuencias razonables sobre integridad y continuidad del sistema, pendientes de validación por la clínica. No se atribuyen volúmenes de pacientes, pérdidas económicas ni tiempos tolerables no medidos.

Tabla 4. Procesos soportados y efectos de una interrupción

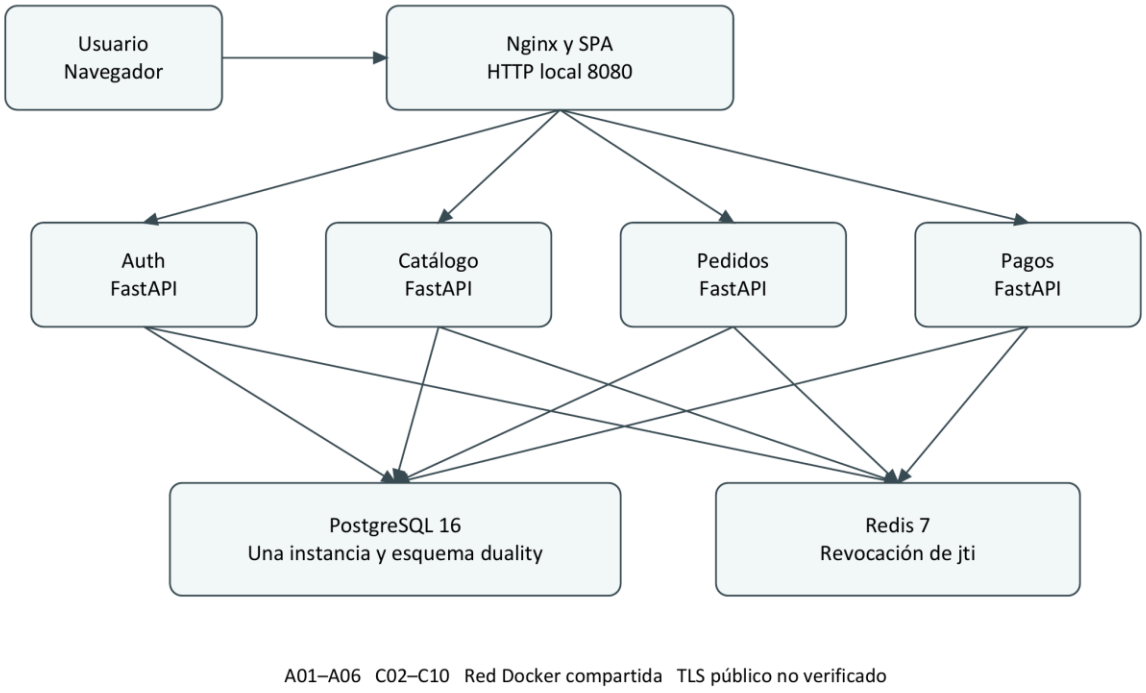
Proceso	Funciones observadas	Consecuencia a validar
Usuarios	Login, logout, roles, altas y desactivación.	Interrupción de acceso o privilegios indebidos.
Pacientes y servicios	Registro administrativo y servicios realizados.	Indisponibilidad o exposición de datos restringidos.
Productos e inventario	Kardex, movimientos y stock derivado.	Falta de disponibilidad o inconsistencia de existencias.
Ventas y pagos	Detalles, confirmación, anulaciones y estado de cuenta.	Saldos o stock incorrectos y pérdida de trazabilidad.
Reportes	Dashboard e informes de operación.	Decisiones administrativas con datos incompletos.

Arquitectura tecnológica real

Se observaron cuatro APIs Python/FastAPI que comparten una instancia PostgreSQL y el esquema duality. Redis mantiene revocaciones de jti, mientras Nginx sirve la interfaz y enruta solicitudes. Los Dockerfiles Python especifican 3.12 y UID 65532; PostgreSQL 16 y Redis 7 están declarados en Compose.

La versión ensayada de PostgreSQL fue 16.15 y la de Python local 3.12.14. Estas versiones ejecutadas no prueban el estado de un proveedor cloud [E03; E06; E10].

Figura 1. Arquitectura observada de la solución



El esquema resume componentes presentes en el repositorio y sus dependencias. Todas las APIs usan PostgreSQL y Redis. El acceso HTTP y la publicación de puertos corresponden a la configuración local; no se acredita TLS público.

Control relacionado: C02–C10, C17. Estado: Parcialmente implementado. Fuente: docs/ARCHITECTURE.md y docker-compose.yml.

Inventario de activos y clasificación de información

El inventario registra activos lógicos confirmados por las fuentes técnicas. La clasificación y los custodios son propuestas sujetas a aprobación. A09 distingue la referencia a proveedores de su operación efectiva; no se incorporan AWS, laptops, routers o VLAN como recursos desplegados sin confirmación. Los respaldos operativos tampoco se dan por existentes [T04].

Tabla 5. Inventario lógico de activos

ID	Activo y proceso	Ubicación o dependencia	Clase y criticidad	Custodio propuesto	Protección
A01	Información de pacientes, servicios realizados, ventas, pagos y usuarios	Tablas duality; APIs y frontend	Restringida / confidencial; alta	Propietaria / administrador técnico	Acceso por necesidad, TLS, minimización, retención aprobada
A02	PostgreSQL y objetos de integridad	Imagen postgres:16-alpine; SQL 001–003; volumen postgres_data en Compose	Restringida; alta	Propietaria / DBA designado	Rol mínimo, respaldo cifrado y ensayo de restauración
A03	Identidades, hashes, JWT, secreto de firma y revocaciones	common/security.py, auth/main.py, Redis	Restringida; alta	Propietaria / administrador técnico	Rotación, revocación fiable, MFA administrativo
A04	APIs administrativas Python/FastAPI	auth, catalogo, pedidos, pagos, common; psycopg	Interna; alta	Producto / equipo técnico por designar	Validación, autorización, errores seguros y revisión
A05	Frontend y proxy	src/web; Nginx; navegador	Código interno; datos restringidos; alta	Equipo técnico / administrador	Codificación de salidas, gestión de sesión y TLS
A06	Contenedores, red y configuración de host	docker/, docker-compose.yml	Interna; alta	Administrador por designar	Reducir puertos, parches, cuentas, límites y monitoreo
A07	Código, pipelines y evidencias	.git, .github/workflows, Jenkinsfile, azure-pipelines.yml	Interna; alta	Propietario repositorio por confirmar / mantenedor	Revisión, ramas protegidas, no exponer secretos
A08	Bibliotecas de aplicación y herramientas de prueba	src/requirements.txt, requirements-dev.txt, requirements-security.txt	Pública (paquetes); dependencia alta	Equipo técnico	Auditoría de avisos y compatibilidad de versiones
A09	Referencias a proveedores externos	GitHub confirmado por configuración; Railway/Neon/Upstash documentados; operación no verificada	Datos según uso, por confirmar	Titular de cuenta por confirmar	Inventario cloud y responsabilidad compartida

Tabla 6. Clasificación y condiciones de tratamiento

Clase	Información de Duality	Condiciones propuestas
Pública	Material comercial autorizado.	Revisión antes de difusión; excluir pacientes y secretos.
Interna	Código, diagramas y procedimientos.	Acceso del equipo autorizado y control de versiones.
Confidencial	Ventas, pagos, reportes y referencias.	Permisos por función, transferencia protegida y conservación aprobada.
Restringida	Pacientes, identidades, hashes, JWT y copias.	Necesidad de conocer, custodia y cifrado cuando aplique; minimizar registros.

Amenazas y evaluación de probabilidad e impacto

La evaluación relaciona cada amenaza con una condición concreta del proyecto. La probabilidad usa valores 1 baja, 2 media y 3 alta; el impacto emplea 1 bajo, 2 medio y 3 alto. El nivel se obtiene con P×I: 1–2 bajo, 3–4 medio y 6–9 alto. Las puntuaciones iniciales y residuales son estimaciones técnicas preliminares, no decisiones aceptadas por la clínica [T05].

Los hallazgos incluyen sesión no verificable, exposición de credenciales, acceso excesivo, XSS, inconsistencias por concurrencia, filtración de errores, exposición de red, dependencias vulnerables, cambios inseguros, pérdida de información y falta de gobierno. Las correcciones reducen condiciones específicas en el laboratorio; no justifican disminuir automáticamente el riesgo de la operación real.

Tabla 7. Matriz de riesgos y valoración inicial

ID y activo	Amenaza	Vulnerabilidad o condición	P	I	Nivel inicial
R01 / A03	Reutilización de sesión	Fallo abierto Redis y claims no exigidos en origen	3	3	9, alto
R02 / A03/A05	Compromiso de credenciales	Fallbacks conocidos, cuenta académica, contraseña antes precargada	3	3	9, alto
R03 / A01/A02/A03	Acceso excesivo o cuenta inactiva	Rol en JWT obsoleto; lecturas amplias; superusuario BD compartido	3	3	9, alto
R04 / A05	XSS y robo de sesión	Interpolación HTML; JWT persistente en localStorage	3	3	9, alto
R05 / A02/A04	Inconsistencia financiera/inventario	Concurrencia y entradas hostiles; cobertura previa textual	2	3	6, alto
R06 / A04/A02	Divulgación por errores o consultas inseguras	409 con texto de excepción SQL; auditoría de eventos incompleta	2	3	6, alto
R07 / A06/A01	Acceso de red o privilegios indebidos	Puertos en interfaces host, HTTP local, web sin endurecimiento validado	3	3	9, alto
R08 / A08/A06	Explotación de componente vulnerable	Avisos en dependencias, imágenes sin escaneo CVE	3	3	9, alto
R09 / A07	Cambio o despliegue inseguro	Pasos exitosos omitidos en corrida #55; main sin protección y rulesets vacíos (E11)	2	3	6, alto
R10 / A02	Pérdida o indisponibilidad de información	Sin respaldo operativo, responsables ni RTO/RPO confirmados	3	3	9, alto
R11 / A01/A07	Controles sin adopción o respuesta tardía	Sin entrevistas/designaciones/aprobación de política	2	3	6, alto
R12 / A09	Falla o acceso indebido de proveedor	Inventario cloud y responsabilidad efectiva no confirmados	2	3	6, alto

Tratamiento y riesgos residuales

Se propone mitigar los doce riesgos mediante controles relacionados con el activo. No existe aceptación ni transferencia formal acreditada. El equipo técnico es responsable propuesto de implementar y probar; la propietaria debe confirmar impacto, recursos y aceptación del riesgo. El residual mantiene alcance local y no representa una medición de producción.

Tabla 8. Tratamiento y residual preliminar

Riesgo	Tratamiento y controles	Residual	Actividad para cierre
R01	Mitigar C02–C04	2×3=6, alto	Disponibilidad de Redis y verificación integrada pendientes
R02	Mitigar C01/C12/C21	3×3=9, alto	Rotación y bootstrap seguro pendientes; quitar prefills solo reduce exposición UI
R03	Mitigar C04/C05/C13/C16	2×3=6, alto	Matriz clínica y rol mínimo aún sin aprobar/implementar
R04	Mitigar C06	2×3=6, alto	Cobertura DOM integral y estrategia de sesión pendientes
R05	Mitigar C07/C09/C10	1×3=3, medio	Ensayo acotado; faltan carreras de edición/anulación y carga
R06	Mitigar C08/C14/C15/C23	2×3=6, alto	Errores y logs completos pendientes de contrato y diseño
R07	Mitigar C17–C20/C38	3×3=9, alto	No se cambia configuración real sin conocer entorno
R08	Mitigar C19/C22	3×3=9, alto	Escaneo detecta, no corrige ni demuestra explotabilidad
R09	Mitigar C24–C26/C29/C40	2×3=6, alto	CI nuevo actualizado solo localmente; falta protección/revisión independiente
R10	Mitigar C11/C27	3×3=9, alto	Restauración sintética exitosa no sustituye continuidad real
R11	Mitigar C28/C32–C39	2×3=6, alto	Borradores necesitan revisión y ejercicio con clínica
R12	Mitigar C30/C31	2×3=6, alto	No se asume SLA ni se transfiere riesgo sin contrato

Matriz de accesos y condiciones de autorización

Las 49 rutas de API se extrajeron de las dependencias de FastAPI y se contrastaron con la matriz técnica. Las lecturas administrativas se permiten a cualquier cuenta activa con rol vigente, salvo gestión de usuarios. ADMIN y OPER comparten diversas operaciones de registro y edición; las bajas y operaciones administrativas dependen de la ruta. El permiso de consulta sobre pacientes debe revisarse por necesidad de conocer [T06; C05; C13].

Tabla 9. Resumen de permisos por rol

Operación	ROL_CONS	ROL_OPER	ROL_ADMIN
Lectura administrativa excepto usuarios	Permitida	Permitida	Permitida
Gestión de usuarios	No	No	Permitida
Registrar y editar pacientes productos servicios ventas pagos	No	Según ruta	Según ruta
Bajas y anulaciones restringidas	No	Solo rutas específicas de servicios realizados	Según ruta
Consulta de roles	Permitida	Permitida	Permitida

La autorización exige JWT válido y no revocado, Redis disponible, cuenta activa y coincidencia del rol con PostgreSQL. La ausencia de autenticación produce 401 y el rol insuficiente produce 403. La verificación no disponible produce 503. Logout sin token retorna 204 sin acción; si recibe token, exige validación y revocación. La matriz completa por endpoint se incorpora en el anexo A.

Requisitos de seguridad trazables

Tabla 10. Requisitos conservados del documento preliminar

ID	Condición verificable	Controles
RS-01	Las rutas administrativas exigen sesión válida y rol permitido.	C02,C03,C04,C05,C13
RS-02	Las cuentas son individuales y las inactivas no pueden iniciar sesión.	C04,C13
RS-03	Las contraseñas se almacenan con PBKDF2-SHA256 y salt.	C01
RS-04	SQL usa parámetros y entradas inválidas no alteran datos.	C07,C08,C15
RS-05	Las salidas de inventario no permiten stock negativo y conservan trazabilidad.	C09,C14

ID	Condición verificable	Controles
RS-06	Ventas y pagos se validan en transacciones consistentes ante concurrencia.	C10
RS-07	Los secretos se inyectan por ambiente y no se exponen en artefactos.	C12,C21
RS-08	Los respaldos tienen operación y recuperación aprobadas.	C11,C27
RS-09	Las etapas requeridas de CI no se aprueban si se omitieron.	C24
RS-10	Los cambios de seguridad mantienen motivo responsable impacto y evidencia.	C29,C40

Adaptación de la política y selección de controles

La selección se fundamenta en activos, criticidad, amenazas, arquitectura y viabilidad de prueba. La política general se adapta al sistema administrativo de Duality mediante C01–C40. No se añaden componentes solo para completar una lista: MFA, red física, IDS/IPS, EDR o nuevos servicios cloud requieren contexto, responsables y capacidad real de operación. El anexo B conserva requisitos, ubicaciones y mecanismos de prueba para cada control [D1, pp. 12–13; T01; T03].

Tabla 11. Adaptación de dominios de política

Dominio	Aplicación en Duality	Pendiente organizacional
Gobierno y activos	Inventario A01–A09 y riesgos R01–R12.	Confirmar infraestructura, titulares y aprobación.
Identidad y datos	PBKDF2, JWT, revocación, roles y SQL parametrizado.	Matriz aprobada, secretos fuertes y rol mínimo BD.
Infraestructura y DevSecOps	Dockerfiles, Compose, CI y herramientas de análisis.	TLS, red, imágenes auditadas y corrida nueva de CI.
Incidentes y continuidad	Escenarios propuestos y restauración sintética.	Canal, responsables, copias periódicas y RTO/RPO.
Terceros y mejora	Proveedores documentados y trazabilidad local.	Confirmar cuentas, contratos, MFA y revisión.

Tabla 12. Matriz de controles seleccionados y estado

ID	Requisito y control	Activo	Riesgo	Estado
C01	Las contraseñas usan PBKDF2-SHA256, salt aleatorio y comparación segura	A03	R02	Implementado y validado
C02	El JWT requiere firma HS256, sub, jti, role, iat y exp válidos	A03	R01	Implementado y validado
C03	La revocación rechaza tokens cerrados y los fallos de Redis devuelven 503	A03	R01	Parcialmente implementado
C04	La sesión protegida exige cuenta activa y rol vigente en PostgreSQL	A03	R03	Parcialmente implementado
C05	Las rutas sensibles rechazan token ausente y rol insuficiente	A04	R03	Parcialmente implementado
C06	Los datos de API insertados en HTML se codifican antes de mostrarse	A05	R04	Parcialmente implementado
C07	La entrada inválida se rechaza por esquema antes de registrar operaciones	A04	R05	Parcialmente implementado
C08	El login parametriza SQL y no interpola el correo recibido	A04	R06	Implementado y validado
C09	Inventario impide stock negativo y modificar movimientos históricos	A02	R05	Implementado y validado
C10	Pagos concurrentes evitan sobrepago y revierten pago si falla confirmación	A02	R05	Implementado y validado
C11	Un dump sintético restaura tablas, totales, stock y trigger de inmutabilidad	A02	R10	Implementado y validado
C12	El formulario de acceso no contiene credenciales precargadas	A05	R02	Implementado y validado
C13	La clínica aprueba identidades, altas, bajas, revisión de accesos y mínimo privilegio	A01	R03	Propuesto
C14	Los eventos críticos conservan actor/resultado sin secretos ni datos excesivos	A02	R06	Parcialmente implementado
C15	Los errores al cliente no revelan SQL, infraestructura ni datos sensibles	A04	R06	Parcialmente implementado
C16	Aplicaciones usan rol PostgreSQL distinto de administración con permisos mínimos	A02	R03	Propuesto
C17	Solo se exponen puertos justificados con límites de confianza y firewall	A06	R07	Parcialmente implementado
C18	Los servidores y contenedores operan con mínimo privilegio y servicios necesarios	A06	R07	Parcialmente implementado
C19	Se revisan parches, imágenes, EDR y bloqueo de equipos reales	A06	R08	Propuesto
C20	El tráfico público y datos almacenados tienen protección de cifrado verificada	A01	R07	Propuesto
C21	Los secretos se separan por ambiente y no se divulgan en evidencias	A03	R02	Parcialmente implementado

ID	Requisito y control	Activo	Riesgo	Estado
C22	Los avisos de dependencias generan reporte y bloquean promoción	A08	R08	Parcialmente implementado
C23	Los hallazgos de análisis estático se revisan y trazan	A04	R06	Parcialmente implementado
C24	Una etapa requerida de deploy/post-deploy no termina bien si falta configuración	A07	R09	Parcialmente implementado
C25	Repositorio exige revisiones, protección de ramas y permisos mínimos	A07	R09	Propuesto
C26	Los ambientes, secretos y datos de prueba permanecen separados	A07	R09	Parcialmente implementado
C27	Respaldos tienen responsable, frecuencia, retención y RTO/RPO aprobados	A02	R10	Propuesto
C28	Los incidentes siguen reporte, clasificación, contención, recuperación y revisión	A01	R11	Propuesto
C29	Todo cambio relevante registra motivo, actor, alcance, impacto, pruebas y revisión	A07	R09	Parcialmente implementado
C30	Cada tercero registra datos, accesos, dependencia, riesgo y recuperación	A09	R12	Propuesto
C31	Cloud documenta responsabilidad compartida, IAM/MFA/red/logs/alertas	A09	R12	Propuesto
C32	La política general define objetivo, alcance, principios, marco y aplicabilidad	A01	R11	Propuesto
C33	Gobierno asigna propietarios de riesgos, autoridades y revisión	A01	R11	Propuesto
C34	Activos tienen inventario, propietario, clasificación, criticidad y manejo	A01	R11	Parcialmente implementado
C35	Datos se clasifican y se decide retención, transferencia y eliminación	A01	R11	Propuesto
C36	Riesgos vinculan activo, amenaza, vulnerabilidad, P/I, tratamiento y residual	A01	R11	Parcialmente implementado
C37	Casos de uso, componentes, despliegue y secuencia incorporan controles trazables	A04	R11	Parcialmente implementado
C38	La red física, Wi-Fi/VPN/administración remota y monitoreo se verifican si aplican	A06	R07	Propuesto
C39	Excepciones, terceros, uso de IA y mejora continua tienen revisión	A01	R11	Propuesto
C40	Las evidencias registran entorno, fecha, commit, procedimiento, resultado y límites	A07	R09	Implementado y validado

Implementaciones realizadas y registro de cambios

La auditoría reforzó common/security.py con claims obligatorios, tratamiento de fallos de Redis y verificación de cuenta y rol en PostgreSQL. La autorización expresa cubrió esos tres cambios. También se codificaron salidas de datos del frontend, se retiraron valores precargados del formulario y se ajustaron estados de CI y exclusiones de artefactos. El modelo relacional y los contratos de negocio se conservaron; no se migraron datos persistentes [T07; E01; E02; E04].

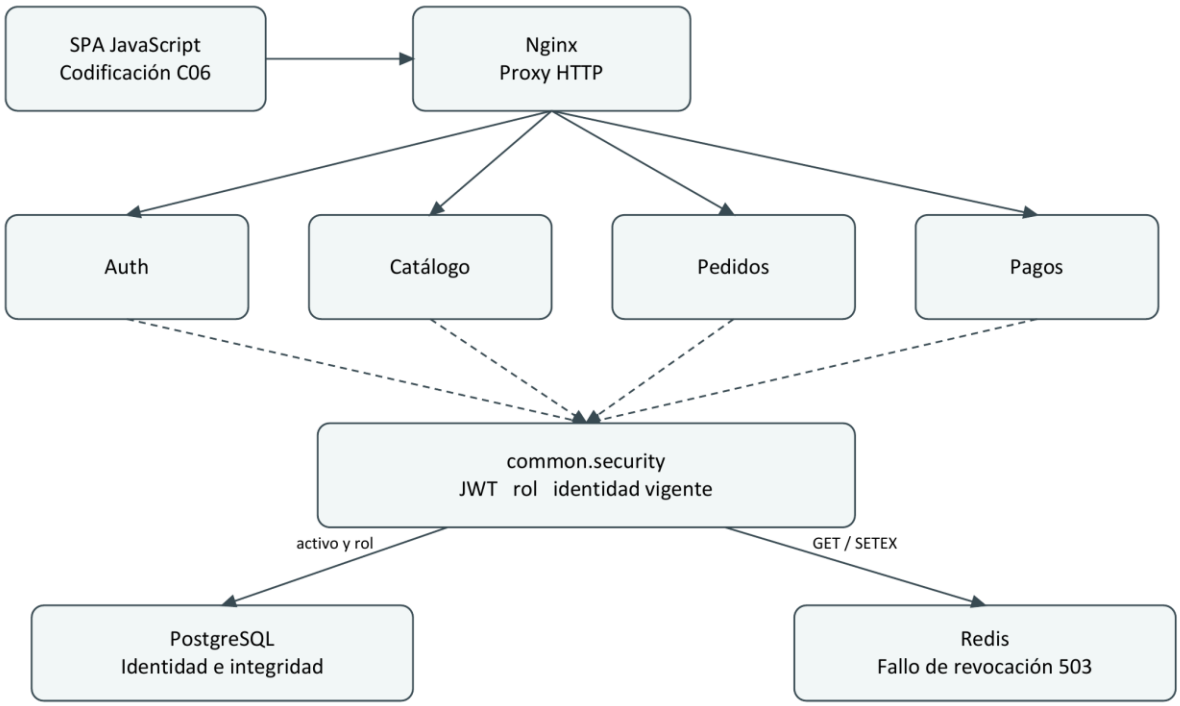
Tabla 13. Bitácora resumida de cambios de seguridad

Cambio	Motivo y elemento	Resultado comprobado
CH01	H01–H03/R01/R03; common/security.py	Regresión local aprobada; integración de API/Redis/BD pendiente
CH02	H05/R04; app.js	Prueba JavaScript aprobada; DOM integral pendiente
CH03	R02; index.html	Formulario vacío comprobado en navegador
CH04	H08/R09; ci.yml, security.yml, azure-pipelines.yml, requirements-security.txt	Revisión local, sin corrida remota; gate de dependencias detectará avisos abiertos
CH05	R02/R09; .gitignore, .dockerignore	Configuración local; documentos fuente permanecen fuera de repo
CH06	H11/H12/R05/R10; tests/test_audit_*.py, security_frontend.cjs y colector	69 pruebas aprobadas; 6 omitidas explícitamente
CH07	R11; docs/seguridad y ARCHITECTURE.md	Borradores sujetos a aprobación organizacional

Seguridad en diagramas UML

Las figuras siguientes representan las fuentes UML existentes y las dependencias observadas. Se prepararon como diagramas documentales para lectura académica, no como capturas de infraestructura operativa. La matriz completa precisa los permisos de cada ruta; los dibujos no sustituyen esa especificación ni la evidencia de pruebas [T08; C37].

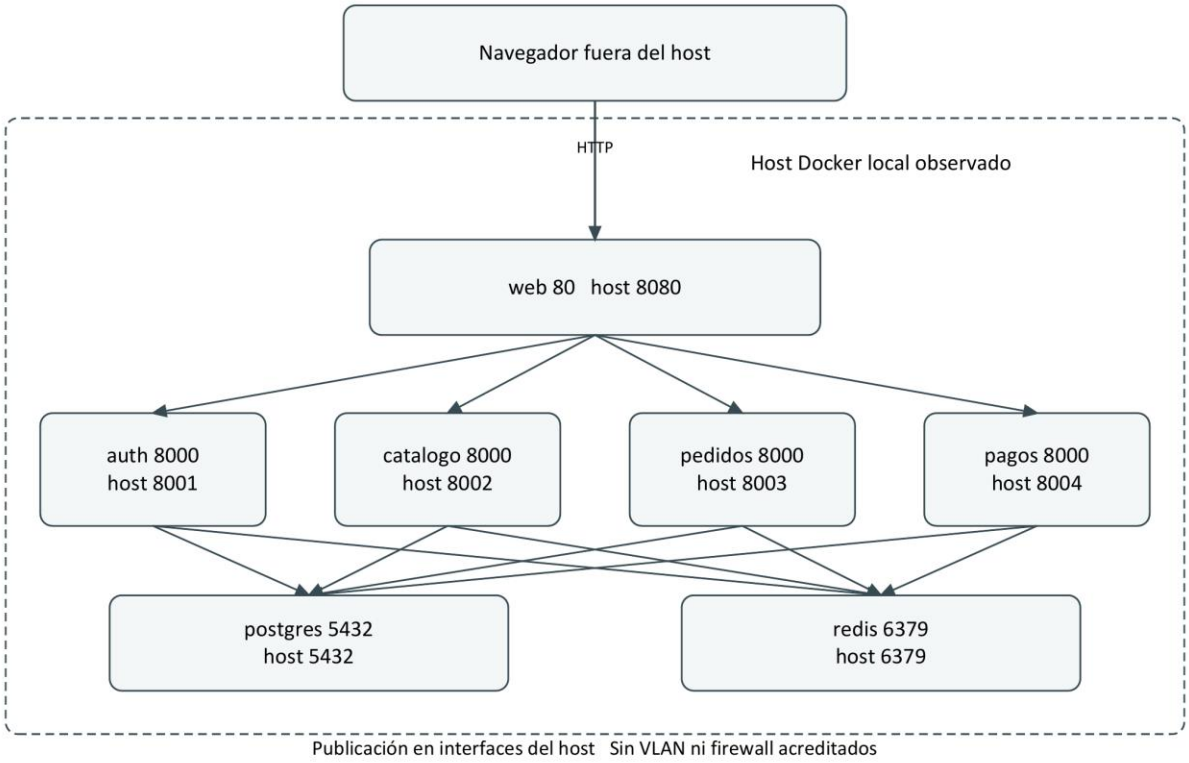
Figura 2. Componentes y verificaciones compartidas de seguridad



Las cuatro APIs incorporan common.security. Este componente valida el token, consulta revocación en Redis y verifica la cuenta en PostgreSQL. La dependencia común concentra decisiones de acceso y también dependencias de disponibilidad.

Control relacionado: C02–C05, C08–C10. Estado: Parcialmente implementado. Fuente: diagramas/componentes.puml y src/common/security.py.

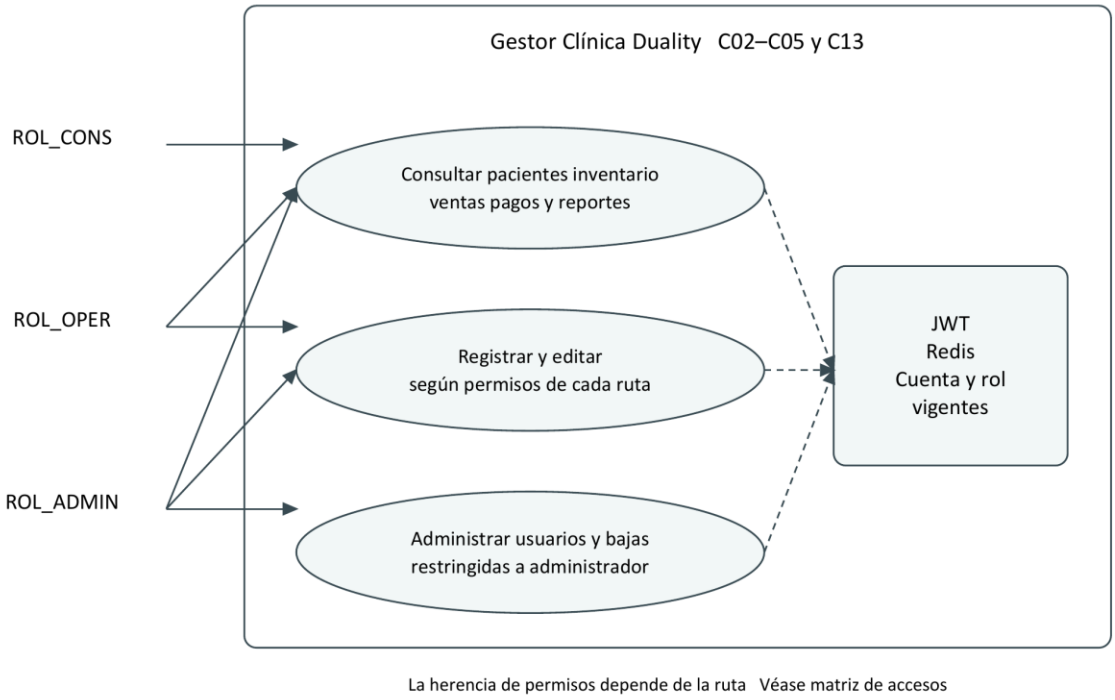
Figura 3. Despliegue local y límites de confianza



La frontera punteada representa el host Docker de la configuración local. Compose publica web, APIs, PostgreSQL y Redis. No se dibujan VLAN, VPN, TLS público o recursos cloud no confirmados. La exposición de puertos mantiene abierto R07.

Control relacionado: C17–C20, C38. Estado: Parcialmente implementado. Fuente: diagramas/despliegue.puml y docker-compose.yml.

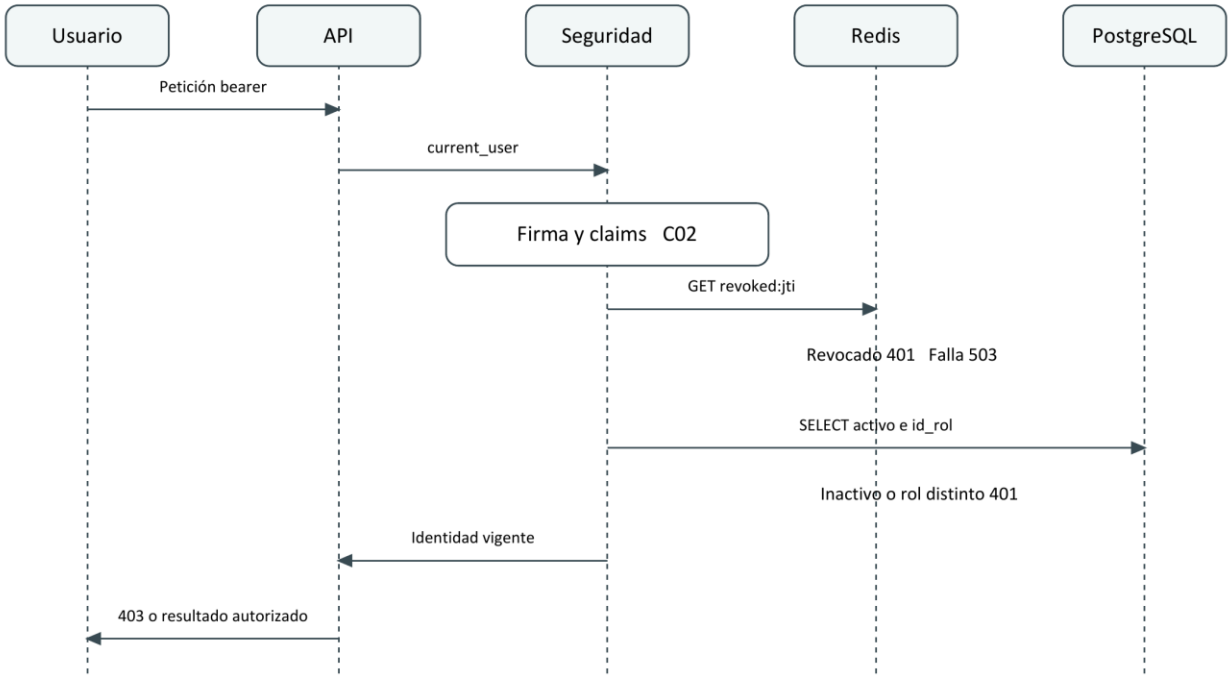
Figura 4. Casos de uso y control de acceso por rol



El rol de consulta dispone de lecturas administrativas; operación y administración amplían acciones según la ruta. La comprobación común incluye JWT, revocación y cuenta vigente. El acceso de lectura a pacientes necesita aprobación de la clínica.

Control relacionado: C02–C05, C13. Estado: Parcialmente implementado. Fuente: diagramas/casos-uso.puml y matriz-accesos.md.

Figura 5. Secuencia de validación de una sesión protegida



Validación local de sesiones con dobles SQL ensayado por separado

La firma y los claims se validan antes de consultar Redis y PostgreSQL. La sesión revocada o identidad no vigente se rechaza; Redis no disponible produce 503. La ruta puede denegar la operación por rol. Las pruebas de esta decisión utilizan dobles controlados.

Control relacionado: C02–C05. Estado: Parcialmente implementado. Fuente: diagramas/secuencia-sesion.puml y tests/test_audit_security.py.

Seguridad de aplicaciones

PBKDF2-SHA256 utiliza salt aleatorio y comparación constante; la función predeterminada declara 390000 iteraciones. JWT usa HS256, expiración y jti; la validación ahora exige sub, role, iat y exp con tipos aceptados. El usuario protegido se contrasta con PostgreSQL para rechazar desactivación, ausencia o cambio de rol. La consulta adicional puede incrementar latencia y vincula acceso con disponibilidad de la BD [C01–C05; E01].

Pydantic controla parte de las entradas y SQL parametriza valores. El test de login con entrada de apariencia SQL verifica que permanece como parámetro, no como consulta interpolada. El frontend codifica datos antes de insertarlos en HTML y protege identificadores en handlers, aunque falta un flujo de XSS completo en navegador. JWT continúa en localStorage; varios errores 409 todavía utilizan texto de excepción SQL y deben sanearse con autorización de impacto contractual [C06–C08; C15; E02].

Seguridad de PostgreSQL e integridad transaccional

La base conserva claves, restricciones CHECK, vistas, triggers y procedimientos sobre el esquema duality. Las ventas y productos usan FOR UPDATE para serializar operaciones sensibles. La prueba de dos salidas concurrentes sobre stock 10, por cantidad 7 cada una, admite una sola salida y deja 3. Los movimientos históricos no se pueden modificar mediante UPDATE en el escenario ensayado [C09; E03; R3].

Para una venta de 10, dos pagos de 7 en paralelo no generan sobrepago: una operación se acepta. Completar el saldo confirma la venta y genera un único movimiento de salida. Un pago cuya confirmación falla por stock insuficiente se revierte y la venta continúa pendiente. Estas verificaciones usan PostgreSQL real y datos sintéticos; no cubren todas las carreras de edición, anulación o descuento [C10; E03].

Compose usa POSTGRES_USER también como usuario de aplicación. En la imagen oficial esa cuenta inicial tiene privilegios administrativos, por lo que la separación de roles queda propuesta. La configuración no demuestra cifrado en reposo ni backup operativo. Los scripts de inicialización incluyen recreación destructiva del esquema y no deben utilizarse como migración sobre información existente [C16; C20; C27].

Seguridad de Redis y gestión de sesiones

La revocación utiliza una clave por jti con expiración asociada a la vigencia restante del token. El código usa SETEX; la documentación de Redis describe que establece valor y tiempo de expiración. Los límites de conexión y lectura configurados son de dos segundos. Cuando la consulta o escritura no puede verificarse, se retorna 503 y no se acepta el cierre como exitoso [C03; E01; R4].

Las pruebas sustituyen Redis para reproducir revocación y fallos, por lo que C03 permanece parcial. No se acreditan persistencia real de revocaciones ante reinicio, alertas o recuperación de Redis en un servicio desplegado. La protección reduce el riesgo de aceptar sesiones no verificables, pero puede denegar temporalmente acceso durante una indisponibilidad.

Seguridad de contenedores y redes

La imagen auth actualizada se construyó y su importación se ejecutó con UID 65532 en un contenedor sin red, read-only, sin capabilities y con no-new-privileges. El log confirma uid=65532 y auth_import=ok. Fue una prueba de construcción e importación, no del stack completo. Los flags de endurecimiento pertenecen al ensayo y no están aplicados a Compose [C18; E06; R5].

Compose publica 8080, 8001–8004, 5432 y 6379 en interfaces del host sin una dirección de loopback explícita. Esto permite acceso directo que no depende del proxy. No se verificó un firewall que compense la exposición. C17 y C18 son parciales; TLS público, segmentación y revisión del host siguen propuestos. No se ejecutó un escáner CVE de imágenes [E05; E10].

Seguridad DevSecOps y repositorio

Se conservaron las definiciones de GitHub Actions, Jenkins y Azure Pipelines. La configuración local nueva usa exit 1 cuando una etapa requerida carece de la variable de despliegue o de la URL para validación posterior; también añade análisis de dependencias y código y reduce la impresión de configuración Compose. No hubo ejecución remota de estos cambios [C22–C24; E10].

La consulta histórica de GitHub encontró main sin protección y rulesets vacíos. La corrida 55, del 10 de octubre de 2026 y commit base, registra éxito de jobs. Sus logs indican que no se ejecutó el despliegue ni las pruebas posteriores por falta de variables. Por tanto, el estado success no demuestra promoción efectiva del sistema. La protección de ramas sigue propuesta y requiere autorización externa; no se modificó en esta tarea [C25; E11; R6].

Vulnerabilidades de dependencias y análisis estático

La auditoría de paquetes instalados devolvió 50 registros de avisos para cuatro paquetes y 31 identificadores de aviso distintos. Existen duplicados y alias: no corresponden necesariamente a 50 vulnerabilidades únicas ni a 31 CVE. El informe no demuestra explotación. La corrección requiere evaluar aplicabilidad y compatibilidad, especialmente FastAPI/Starlette y PyJWT [E08].

Tabla 14. Avisos de dependencias registrados

Paquete	Versión	Registros	IDs distintos
pip	25.0.1	12	6
pyjwt	2.10.1	22	17
pytest	8.3.4	2	1
starlette	0.41.3	14	7

Algunos avisos PyJWT se refieren a JWKS o combinaciones de algoritmos que no usa esta implementación HS256 de clave estática; un aviso está disputado por el proveedor según el reporte. Esto limita la afirmación de explotabilidad, sin cerrar el riesgo. FastAPI 0.115.6 exige Starlette anterior a

0.42, por lo que forzar una actualización aislada puede romper compatibilidad. Pip y pytest afectan herramientas de desarrollo o CI. El escaneo corresponde al entorno Windows instalado, no a un SBOM completo del contenedor Linux.

Bandit registró B105 de severidad baja sobre el literal bearer y B608 media sobre construcción de UPDATE. La primera no identifica una contraseña real; la segunda usa columnas de una lista fija con valores parametrizados. La revisión no demuestra inyección explotable y tampoco sustituye las pruebas o el examen del resto de la aplicación [E09].

Proveedores cloud y responsabilidad compartida

GitHub tiene configuración e histórico verificables. Railway, Neon y Upstash se mencionan en documentación o configuración, pero no se acreditaron sus recursos activos, permisos, contratos o datos almacenados. AWS se conserva como previsión y no se representa desplegado. No hay base para afirmar disponibilidad superior al 99% ni recuperación automática [T09; E11].

Tabla 15. Proveedores y dependencias documentadas

Proveedor	Base de confirmación	Control o validación pendiente
GitHub	Remoto del repositorio y workflows presentes	R09: MFA, revisiones, reglas de rama y contents:read
Jenkins	Jenkinsfile presente, ejecución histórica mencionada en preliminar; no reejecutada	R09: aislar agente, limitar credenciales, revisar plugins y permisos
Azure DevOps	azure-pipelines.yml y docs DEVOPS_1; sin corrida verificada	R09: revisar service connections, permisos y logs; no imprimir Compose con secretos
Railway	Hooks de staging y aliases documentados, operación no verificada	R12: permisos, TLS, límites, alertas y secretos distintos
Neon	Documentación menciona PostgreSQL externo, cuenta no verificada	R03/R10/R12: rol mínimo, cifrado y backup independiente
Upstash	Referencia documental a Redis, sin instancia verificada	R01/R12: TLS, permisos, persistencia y disponibilidad
AWS	Solo previsión del documento preliminar	No agregar como activo desplegado ni inventar IAM/VPC/SLA
PyPI / imágenes oficiales Docker	Dependencias descargadas para laboratorio	R08: fijación, avisos, hashes/digests y escaneo de imágenes

El proveedor opera el servicio contratado según su plan; el titular del proyecto debe verificar identidades, permisos, secretos, configuración, datos y recuperación que le corresponden. El equipo

mantiene código y dependencias; la clínica decide finalidad, custodia y aceptación de riesgo. Deben confirmarse propietarios, ambientes, regiones, accesos, condiciones contractuales y alternativas de recuperación. No se ha verificado una pasarela bancaria externa en el módulo de pagos.

Gestión de incidentes y continuidad

La respuesta propuesta comprende reporte, registro, clasificación, preservación, contención, erradicación, recuperación y lecciones aprendidas. Los escenarios seleccionados responden a activos y riesgos del sistema. El canal, los responsables y las autoridades para detener operaciones o comunicar externamente no están confirmados; no se realizaron simulacros con personal de la clínica [T10; C28].

Tabla 16. Escenarios de incidente y criterios de recuperación

Escenario	Activo riesgo y control	Respuesta y cierre
Cuenta o JWT comprometido	A03/R01-R03/C02-C05	Desactivar cuenta; revocar jti si Redis disponible; evaluar rotación con impacto en todas las sesiones; investigar accesos Recuperación: Token anterior rechazado, usuario vigente autorizado y evidencia protegida
Redis no disponible	A03/R01/C03	503 impide verificar sesión; alertar; restaurar servicio y persistencia; no cambiar a fallo abierto Recuperación: Verificación y logout funcionan con Redis; probar jti previamente revocado
Stock/pagos inconsistentes	A02/R05/C09-C10	Suspender operaciones afectadas, preservar movimientos/transacciones, conciliar; ajustes compensatorios autorizados Recuperación: Totales, saldo, kardex e historial conciliados
Dependencia o despliegue defectuoso	A07-A08/R08-R09/C22-C26	Bloquear promoción, identificar versión y exposición, probar corrección; rollback compatible sin borrar datos Recuperación: Regresión aprobada, artefacto conocido y validación autorizada
Pérdida BD/proveedor	A02-A09/R10-R12/C11,C27,C31	Evaluar alcance con proveedor, proteger copia, restaurar en destino distinto y verificar Recuperación: Recuperación validada y aprobación de retorno; RTO/RPO medidos contra objetivos acordados

La restauración ejecutada obtiene un dump del esquema duality en memoria y lo aplica a audit_restore en el laboratorio. Compara cantidades de productos, movimientos y pagos, suma de pagos y stock; también verifica el trigger que impide modificar movimientos. El dump no se exporta. La prueba técnica C11 está validada en ese alcance, mientras C27 continúa propuesto para respaldos operativos [E03; T11].

Tabla 17. Decisiones de continuidad pendientes de aprobación

Decisión	Información necesaria	Estado
RTO	Tiempo tolerable desde incidente hasta servicio verificado; dependencias y capacidad de recuperación.	Propuesto
RPO	Pérdida temporal máxima tolerable según procesos y datos.	Propuesto
Frecuencia y retención	BIA, clasificación, capacidad de almacenamiento y obligaciones verificadas.	Propuesto
Custodia y ubicación	Titulares, suplentes, copia fuera del host, cifrado y acceso mínimo.	Propuesto
Validación operativa	Simulacro de servicio completo, medición y aprobación de retorno.	Propuesto

Pruebas y criterios de validación

La ejecución final se realizó el 23 de octubre de 2026, entre 12:29:32 y 12:30:00, hora de Guatemala, mediante el colector local. El XML registra 75 casos, 69 aprobados, seis omitidos y cero fallos o errores. La línea base registra 33 aprobados y una omisión; cinco casos de staging no fueron seleccionados en esa ejecución. Las cinco pruebas SQL están incluidas en las 69 finales y no deben sumarse nuevamente [E01; E03].

Tabla 18. Plan y resultados de pruebas controladas

Caso	Control y riesgo	Prueba positiva y negativa	Evidencia y alcance
T01	C01/R02	Hash y verificación con salt distinto / Contraseña incorrecta/hash malformado	E01
T02	C02,C04/R01,R03	Login válido y JWT emitido / Login incorrecto/inactivo, JWT expirado, firma distinta, claims ausentes o tipos inválidos	E01
T03	C03/R01	Petición antes de logout / JWT revocado; fallos GET/SETEX Redis producen 503	E01 (dobles)
T04	C04,C05/R03	Cuenta activa y mismo rol / Sin token en cuatro servicios, rol insuficiente, cuenta eliminada/desactivada/rol cambiado, BD caída	E01 (dobles)
T05	C07,C08/R05,R06	Consulta parametrizada / Correo tipo SQL injection permanece parámetro; monto negativo 422	E01
T06	C06/R04	Formato de tabla se conserva / Etiquetas/comillas codificadas, IDs no rompen handler	E02 (funciones JS)
T07	C09/R05	Stock inicial 10 / Salidas simultáneas de 7: una acepta, otra falla; final 3; UPDATE movimiento rechazado	E03 (BD real)
T08	C10/R05	Venta total 10; completar pago confirma una vez / Dos pagos de 7: solo uno acepta; stock insuficiente revierte pago	E03
T09	C11/R10	pg_dump/restauración con mismas cantidades/totales/stock / UPDATE movimiento restaurado falla	E03
T10	C18/R07	Build auth y UID 65532 / Ejecutar sin red, read-only y sin capabilities	E06 (solo importación, no stack completo)
T11	C22,C23/R08	Analizadores producen reporte / Avisos no equivalen a explotación confirmada	E08/E09
T12	C24/R09	Revisar etapas y permisos de CI / Falta configuración: exit 1 en archivo	E10 (sin run externo)
T13	C12/R02	Pantalla local vacía sin prefill / Inspección de ausencia de credenciales por defecto en inputs	E04

Tabla 19. Resultados de las ejecuciones y análisis

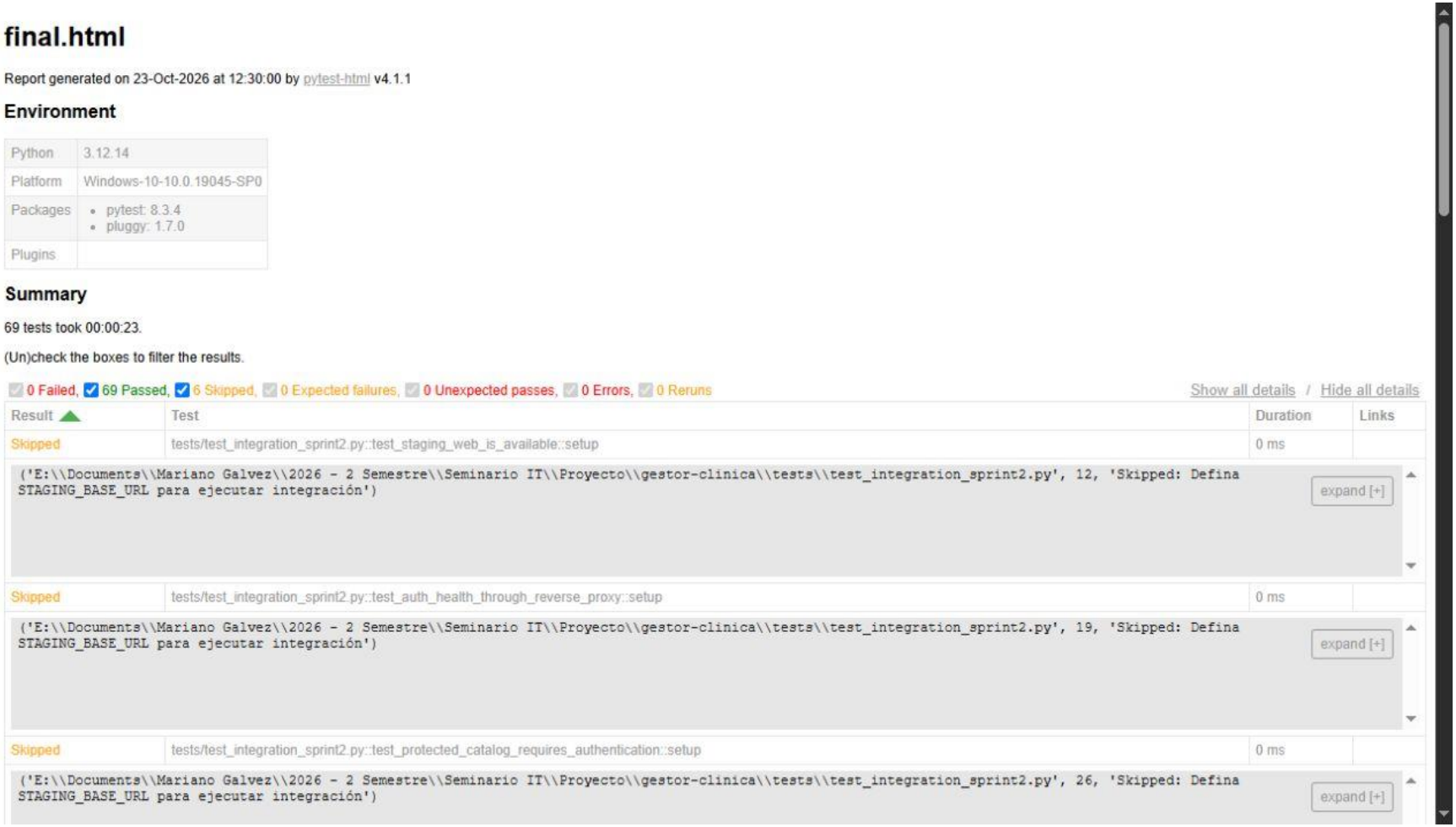
Ejecución	Resultado	Interpretación
Línea base local	33 aprobadas; 1 omitida; 5 no seleccionadas.	Pruebas existentes antes de cambios.
Suite final local	69 aprobadas; 6 omitidas; 0 fallos; 1 warning.	Incluye SQL real y decisiones de API con dobles.
SQL suplementario	5 aprobadas.	Mismos cinco escenarios incluidos en la suite final.
JavaScript	PASS adicional.	Funciones de codificación; no prueba DOM completa.
Dependencias	Exit 1; 50 registros en 4 paquetes.	Avisos abiertos, no explotación demostrada.
Bandit	Dos alertas revisadas.	No prueba ausencia de vulnerabilidades.
Build auth	UID 65532; importación correcta.	Sin stack completo ni análisis CVE de imagen.

Las seis omisiones corresponden a tres casos de integración, uno de rendimiento y uno Selenium sin STAGING_BASE_URL, y un smoke sin SMOKE_BASE_URL. La captura local de la pantalla de acceso no reemplaza Selenium ni prueba login en un despliegue. El warning de la corrida final es una deprecación de anyio/Starlette TestClient. La aprobación de contratos existentes reduce regresión, pero no sustituye aceptación funcional completa de pacientes, servicios, inventario, ventas, pagos y reportes.

Evidencias principales

Se insertan físicamente las tres capturas PNG disponibles. Para mantener proporción y lectura se presentan en páginas horizontales. El texto de los resultados y sus límites se conserva también como contenido editable. Las figuras 6 a 8 son capturas auténticas; las figuras 1 a 5 son diagramas documentales, no evidencia de ejecución. Las fechas y el commit de cada artefacto se interpretan según su registro original [E01–E04; E07].

Figura 6. Reporte final de pruebas locales



final.html

Report generated on 23-Oct-2026 at 12:30:00 by pytest-html v4.1.1

Environment

Python	3.12.14
Platform	Windows-10-10.0.19045-SP0
Packages	• pytest: 8.3.4 • pluggy: 1.7.0
Plugins	

Summary

69 tests took 00:00:23.

(Un)check the boxes to filter the results.

0 Failed, 69 Passed, 6 Skipped, 0 Expected failures, 0 Unexpected passes, 0 Errors, 0 Reruns — Show all details / Hide all details

Result	Test	Duration	Links
Skipped	tests/test_integration_sprint2.py::test_staging_web_is_available::setup	0 ms	

```
('E:\\Documents\\Mariano Galvez\\2026 - 2 Semestre\\Seminario IT\\Proyecto\\gestor-clinica\\tests\\test_integration_sprint2.py', 12, 'Skipped: Defina STAGING_BASE_URL para ejecutar integración')
```

expand [+]

Skipped	tests/test_integration_sprint2.py::test_auth_health_through_reverse_proxy::setup	0 ms	

```
('E:\\Documents\\Mariano Galvez\\2026 - 2 Semestre\\Seminario IT\\Proyecto\\gestor-clinica\\tests\\test_integration_sprint2.py', 19, 'Skipped: Defina STAGING_BASE_URL para ejecutar integración')
```

expand [+]

Skipped	tests/test_integration_sprint2.py::test_protected_catalog_requires_authentication::setup	0 ms	

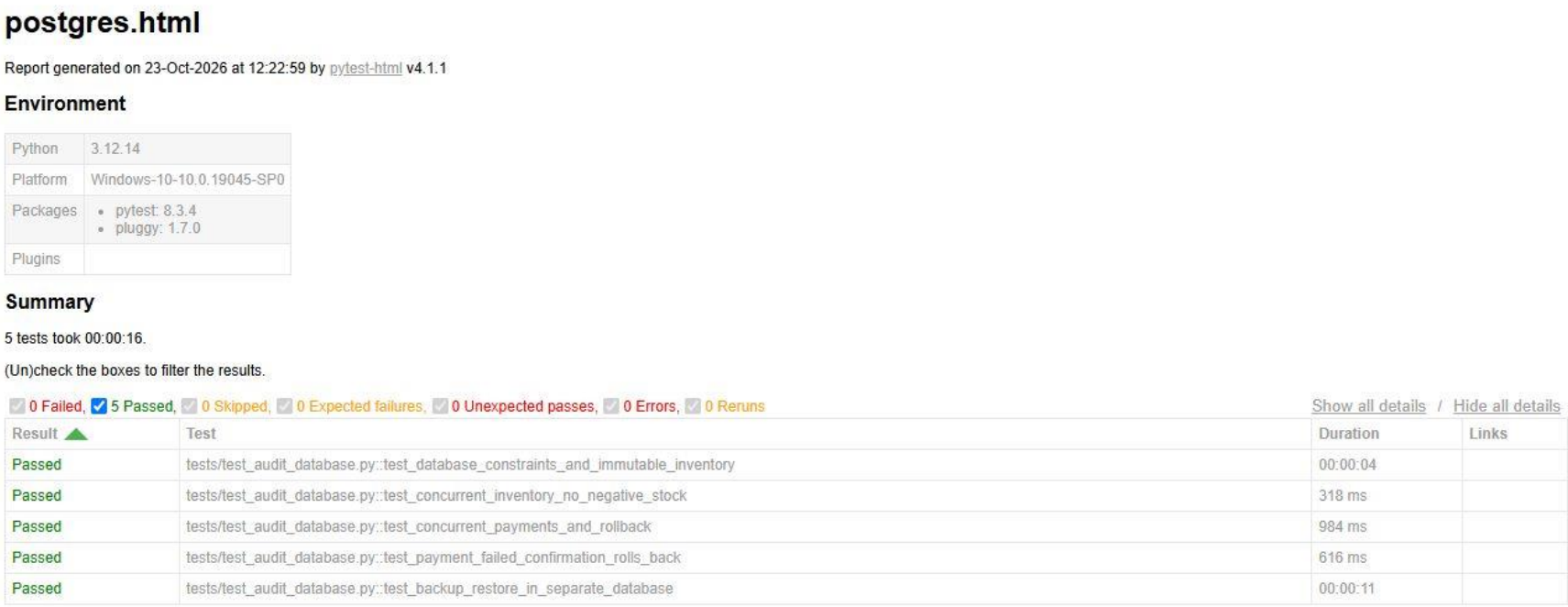
```
('E:\\Documents\\Mariano Galvez\\2026 - 2 Semestre\\Seminario IT\\Proyecto\\gestor-clinica\\tests\\test_integration_sprint2.py', 26, 'Skipped: Defina STAGING_BASE_URL para ejecutar integración')
```

expand [+]

La captura del reporte pytest muestra 69 pruebas aprobadas y seis omitidas. Los casos omitidos exigen servicios web o staging. El resultado demuestra la ejecución local registrada y no el cumplimiento integral de los 40 controles.

Control relacionado: C01–C05, C07–C11; RS-01–RS-06. Estado: Implementado y validado para la corrida local. Fuente: evidencias/devsecops/pytest-local.png; final.xml; final.html.

Figura 7. Pruebas reales de integridad concurrencia y restauración



postgres.html

Report generated on 23-Oct-2026 at 12:22:59 by pytest-html v4.1.1

Environment

Python	3.12.14
Platform	Windows-10-10.0.19045-SP0
Packages	• pytest: 8.3.4 • pluggy: 1.7.0
Plugins	

Summary

5 tests took 00:00:16.

(Un)check the boxes to filter the results.

0 Failed, 5 Passed, 0 Skipped, 0 Expected failures, 0 Unexpected passes, 0 Errors, 0 Reruns — Show all details / Hide all details

Result	Test	Duration	Links
Passed	tests/test_audit_database.py::test_database_constraints_and_immutable_inventory	00:00:04	
Passed	tests/test_audit_database.py::test_concurrent_inventory_no_negative_stock	318 ms	
Passed	tests/test_audit_database.py::test_concurrent_payments_and_rollback	984 ms	
Passed	tests/test_audit_database.py::test_payment_failed_confirmation_rolls_back	616 ms	
Passed	tests/test_audit_database.py::test_backup_restore_in_separate_database	00:00:11	

El reporte suplementario muestra cinco casos SQL aprobados en PostgreSQL real: restricciones e inmutabilidad, inventario concurrente, pagos concurrentes, rollback y restauración. Estos casos también se repitieron dentro de la corrida final.

Control relacionado: C09–C11; RS-05, RS-06, RS-08. Estado: Implementado y validado en laboratorio. Fuente: evidencias/bases-datos/postgres.png; postgres.xml.

Figura 8. Formulario local sin credenciales precargadas



La captura muestra correo y contraseña vacíos tras retirar sus valores precargados. Fue obtenida en un servidor estático local, sin backend. La cuenta académica permanece en SQL y debe rotarse antes de uso real; la figura no demuestra autenticación productiva.

Control relacionado: C12; RS-07. Estado: Implementado y validado para el formulario. Fuente: evidencias/autenticacion/login-local.png y devsecops/configuracion.json.

Evidencias de logs y reportes sin captura

Los siguientes extractos se transcriben desde archivos auténticos y no constituyen capturas fabricadas. Conservan la referencia y la limitación de cada artefacto. Los logs completos y JSON permanecen en el repositorio local, fuera de las páginas cuando su volumen no aporta legibilidad.

Tabla 20. Extractos verificables de resultados

Evidencia	Extracto original o valor registrado	Qué demuestra y límite
E01 final.txt	69 passed, 6 skipped, 1 warning in 26.75s	Ejecución final local; no producción.
E02 frontend.txt	PASS: texto HTML, columnas, formato e identificadores con datos sintéticos	Prueba de funciones JavaScript; no DOM completo.
E06 runtime-auth.txt	uid=65532 / auth_import=ok	Importación como usuario no root; no stack completo.
E11 job 114279681107	RAILWAY_STAGING_DEPLOY_HOOKS no está configurado; el stage queda preparado pero no ejecuta despliegue.	Advertencia histórica de no despliegue pese a job exitoso.
E11 job 114279702157	STAGING_BASE_URL no está configurado; se omiten pruebas post-deploy.	Validación posterior omitida en corrida histórica.
E11 main y rulesets	protegida=false; proteccion_habilitada=false; rulesets=[]	Ausencia de protección observada, sin cambiar configuración.

Riesgos residuales y plan de mejora

Los riesgos no se consideran cerrados por la cantidad de pruebas. Persisten fallbacks de secretos y bootstrap académico, privilegios administrativos compartidos en la BD, publicación amplia de puertos, HTTP local, errores SQL expuestos, avisos de dependencias, JWT en localStorage y falta de adopción operativa. La consulta de GitHub confirmó protección deshabilitada en main; no se habilitó por tratarse de un cambio externo sujeto a autorización [T05; E08; E10; E11].

Tabla 21. Plan de mejora y criterios de cierre

Prioridad y frente	Riesgo y control	Tratamiento recomendado	Responsable propuesto	Criterio de cierre
P1 Secretos y bootstrap	R02 / C21	Rotar credenciales y secreto, definir configuración explícita por ambiente y acceso seguro.	Mantenedor y administrador por designar	Falta autorización/configuración real; pruebas de rotación y ausencia de defaults.
P1 Rol mínimo de BD	R03 / C16	Separar cuenta de aplicación y administración con migración segura.	DBA por designar	Rechazo de DDL y privilegios efectivos mínimos sin romper módulos.
P1 Exposición de red y TLS	R07 / C17,C20	Aprobar puertos requeridos, limitar exposición y verificar TLS público.	Administrador por designar	Diagrama y reglas efectivos; pruebas desde origen permitido y denegado.
P1 Dependencias y errores	R06,R08 / C15,C22	Migración compatible y saneamiento de respuestas con aprobación de contratos.	Equipo de desarrollo	Regresión aprobada y avisos tratados o excepción formal.
P1 Protección de main	R09 / C25	Definir revisión obligatoria y checks; habilitar protección autorizada.	Titular del repositorio	Reglas efectivas y prueba de rechazo a promoción no autorizada.
P2 Integración y UAT	R01,R03,R04 / C03–C06	Probar Redis real, rutas por rol, XSS DOM y flujos completos con usuarios autorizados.	Equipo técnico y responsable operativo	Resultados desplegados y aceptación documentada.
P2 Backups e incidentes	R10,R11 / C27,C28	Aprobar BIA, RTO/RPO, responsables, copias y simulacro.	Propietaria y administrador	Restauración de servicio, tiempos y responsables aceptados.
P2 Gobierno y proveedores	R11,R12 / C30–C39	Confirmar activos físicos, política, clasificación y contratos/cuentas.	Propietaria y titulares de cuenta	Actas y decisiones verificables con residual aprobado.

8 Análisis de resultados

La principal mejora verificable es que la evidencia permite delimitar el alcance de cada afirmación. La validación JWT y las funciones de contraseña se ejercitan localmente; la integridad y restauración usan PostgreSQL real; la disponibilidad de Redis y la operación de la clínica no se presumen. La diferencia entre 69 pruebas y 40 controles impide usar una cifra de aprobación como indicador de cumplimiento total.

Los ocho controles validados corresponden a C01, C02, C08, C09, C10, C11, C12 y C40, siempre en sus alcances definidos. Dieciocho controles conservan implementación parcial por falta de integración, cobertura, evidencia o adopción. Catorce permanecen propuestos por ausencia de implementación, datos organizacionales o autorización. La distribución no representa una puntuación ponderada: los controles abiertos pueden concentrar riesgos de alto impacto.

El ensayo transaccional aporta evidencia más fuerte que una búsqueda textual de FOR UPDATE, pero dos clientes y datos sintéticos no cubren todas las carreras posibles. La restauración verifica el esquema y algunos invariantes, no la continuidad del servicio completo. Del mismo modo, las alertas de dependencias y Bandit deben interpretarse por aplicabilidad, evitando tanto ocultarlas como presentarlas como explotación confirmada.

La corrida histórica de CI demuestra que un job exitoso puede ocultar una función omitida. El cambio local corrige esa condición de configuración, pero requiere una nueva ejecución autorizada antes de acreditarlo en un pipeline remoto. El conjunto de hallazgos exige cerrar credenciales, privilegios, exposición y gobierno antes de tratar el sistema como listo para información real.

9 Conclusiones

La auditoría técnica y las fuentes revisadas confirman una arquitectura administrativa concreta y controles presentes de contraseñas, sesiones, autorización, consultas e integridad. Se implementaron mejoras autorizadas sin alterar el modelo relacional ni operar sobre producción.

La validación final registró 69 pruebas aprobadas y seis omitidas justificadas. Las pruebas SQL reales comprobaron escenarios de stock, pagos, rollback y restauración, mientras las de autenticación utilizaron dobles controlados. Esta diferencia limita la extrapolación a un ambiente desplegado.

La matriz de 40 controles conserva ocho validados localmente, dieciocho parciales y catorce propuestos. La política, las responsabilidades, el inventario físico y la continuidad requieren aprobación y datos reales de la clínica.

Permanecen riesgos altos de secretos, privilegios, red, dependencias, errores y protección de repositorio. La restauración sintética y el éxito de pruebas no eliminan esos riesgos ni acreditan cumplimiento total de la guía.

10 Recomendaciones

Antes de utilizar información real, priorizar la rotación y eliminación de defaults, separar privilegios de BD, restringir puertos, validar TLS y proteger la rama principal mediante cambios autorizados. Las actualizaciones de dependencias y el saneamiento de errores deben planificarse con regresión funcional y criterios de cierre explícitos.

Completar la integración con Redis real, la matriz de pruebas por ruta y rol, la validación DOM y los flujos de pacientes, inventario, servicios, ventas, pagos y reportes en staging autorizado. Registrar aceptación de usuarios y desempeño del SELECT de identidad añadido a cada petición protegida.

La clínica debe confirmar responsables, políticas, permisos, clasificación, conservación, proveedores y objetivos RTO/RPO. Debe realizar un simulacro de recuperación y un ejercicio de incidentes antes de declarar operativos esos procedimientos. La promoción del código, los cambios externos y la publicación de los insumos requieren las autorizaciones correspondientes.

11 Referencias bibliográficas

[D1] Universidad Mariano Gálvez de Guatemala. (s. f.). Guía proyecto final de Seguridad y Auditoría de Sistemas. Documento del curso, 14 páginas, proporcionado para la revisión.

[D2] Hernández Girón, J., Calderón Estrada, C. A., e Iturbide Cerna, F. G. (2026). Políticas y análisis de seguridad Proyecto Clínica Duality. Documento preliminar del equipo, 8 páginas.

[R1] National Institute of Standards and Technology. (2024). The NIST Cybersecurity Framework (CSF) 2.0. https://doi.org/10.6028/NIST.CSWP.29

[R2] OWASP Foundation. (2025). Application Security Verification Standard 5.0.0. https://asvs.owasp.org/

[R3] PostgreSQL Global Development Group. (s. f.). PostgreSQL 16 Documentation, Explicit Locking. https://www.postgresql.org/docs/16/explicit-locking.html

[R4] Redis. (s. f.). SETEX. https://redis.io/docs/latest/commands/setex/

[R5] Docker. (s. f.). Dockerfile reference, USER. https://docs.docker.com/reference/dockerfile/#user

[R6] GitHub. (s. f.). About protected branches. https://docs.github.com/en/repositories/configuring-branches-and-merges-in-your-repository/managing-protected-branches/about-protected-branches

[T01] Equipo del proyecto. (2026). Matriz de cumplimiento y controles.json. docs/seguridad/matriz-cumplimiento.md; docs/seguridad/controles.json.

[T02] Equipo del proyecto. (2026). Arquitectura y auditoría inicial. docs/ARCHITECTURE.md; docs/seguridad/auditoria-inicial.md.

[T03] Equipo del proyecto. (2026). Política de seguridad. docs/seguridad/politica-seguridad.md.

[T04] Equipo del proyecto. (2026). Inventario de activos. docs/seguridad/inventario-activos.md.

[T05] Equipo del proyecto. (2026). Matriz de riesgos. docs/seguridad/matriz-riesgos.md.

[T06] Equipo del proyecto. (2026). Matriz de accesos. docs/seguridad/matriz-accesos.md.

[T07] Equipo del proyecto. (2026). Gestión de cambios. docs/seguridad/gestion-cambios.md.

[T08] Equipo del proyecto. (2026). Diagramas de casos de uso, componentes, despliegue y sesión. docs/seguridad/diagramas/*.puml.

[T09] Equipo del proyecto. (2026). Proveedores cloud. docs/seguridad/proveedores-cloud.md.

[T10] Equipo del proyecto. (2026). Gestión de incidentes. docs/seguridad/gestion-incidentes.md.

[T11] Equipo del proyecto. (2026). Respaldos y recuperación. docs/seguridad/respaldos-recuperacion.md.

[T12] Equipo del proyecto. (2026). Plan, resultados, trazabilidad e informe para documento universitario. docs/seguridad/plan-pruebas.md; resultados-pruebas.md; matriz-trazabilidad.md; INFORME-PARA-DOCUMENTO-UNIVERSITARIO.md.

[E01–E11] Equipo del proyecto. (2026). Paquete de evidencias técnicas de la auditoría. Índice en docs/seguridad/evidencias/README.md; archivos originales indicados en anexo C. Fecha de consulta documental: 23 de octubre de 2026.

12 Anexos

Anexo A Matriz completa de accesos

Transcripción de la matriz técnica de 49 rutas. Las rutas health y login son públicas; logout sin token no realiza revocación. La comprobación de roles/identidad depende de las condiciones comunes descritas en el cuerpo. La fuente de cada grupo es src/auth/main.py, src/catalogo/main.py, src/pedidos/main.py o src/pagos/main.py.

Tabla 22. Accesos por endpoint observado

Método	Recurso	Privilegio exigido
GET	/api/auth/health	Público
POST	/api/auth/login	Público
GET	/api/auth/me	Cualquier cuenta activa con rol vigente
POST	/api/auth/logout	Sin token: 204 sin acción; con token: JWT y revocación válidos
GET	/api/roles	Cualquier cuenta activa con rol vigente
GET	/api/users	ROL_ADMIN
POST	/api/users	ROL_ADMIN
PUT	/api/users/{user_id}	ROL_ADMIN
DELETE	/api/users/{user_id}	ROL_ADMIN
GET	/api/catalogo/health	Público
GET	/api/catalogo/dashboard	Cualquier cuenta activa con rol vigente
GET	/api/catalogo/patients	Cualquier cuenta activa con rol vigente
GET	/api/catalogo/patients/{patient_id}	Cualquier cuenta activa con rol vigente

Método	Recurso	Privilegio exigido
POST	/api/catalogo/patients	ROL_ADMIN, ROL_OPER
PUT	/api/catalogo/patients/{patient_id}	ROL_ADMIN, ROL_OPER
DELETE	/api/catalogo/patients/{patient_id}	ROL_ADMIN
GET	/api/catalogo/products	Cualquier cuenta activa con rol vigente
POST	/api/catalogo/products	ROL_ADMIN, ROL_OPER
PUT	/api/catalogo/products/{product_id}	ROL_ADMIN, ROL_OPER
DELETE	/api/catalogo/products/{product_id}	ROL_ADMIN
GET	/api/catalogo/services	Cualquier cuenta activa con rol vigente
POST	/api/catalogo/services	ROL_ADMIN, ROL_OPER
PUT	/api/catalogo/services/{service_id}	ROL_ADMIN, ROL_OPER
DELETE	/api/catalogo/services/{service_id}	ROL_ADMIN
GET	/api/catalogo/inventory	Cualquier cuenta activa con rol vigente
GET	/api/catalogo/inventory/movements	Cualquier cuenta activa con rol vigente
POST	/api/catalogo/inventory/movements	ROL_ADMIN, ROL_OPER
GET	/api/catalogo/clinical-services	Cualquier cuenta activa con rol vigente
POST	/api/catalogo/clinical-services	ROL_ADMIN, ROL_OPER
PUT	/api/catalogo/clinical-services/{record_id}	ROL_ADMIN, ROL_OPER
DELETE	/api/catalogo/clinical-services/{record_id}	ROL_ADMIN, ROL_OPER
POST	/api/catalogo/clinical-services/{record_id}/consumptions	ROL_ADMIN, ROL_OPER
POST	/api/catalogo/clinical-services/{record_id}/finalize	ROL_ADMIN, ROL_OPER
GET	/api/pedidos/health	Público

Método	Recurso	Privilegio exigido
GET	/api/pedidos	Cualquier cuenta activa con rol vigente
GET	/api/pedidos/{order_id}	Cualquier cuenta activa con rol vigente
POST	/api/pedidos	ROL_ADMIN, ROL_OPER
PUT	/api/pedidos/{order_id}	ROL_ADMIN, ROL_OPER
POST	/api/pedidos/{order_id}/confirm	ROL_ADMIN, ROL_OPER
POST	/api/pedidos/{order_id}/cancel	ROL_ADMIN
DELETE	/api/pedidos/{order_id}	ROL_ADMIN
GET	/api/pedidos/reportes/diario	Cualquier cuenta activa con rol vigente
GET	/api/pagos/health	Público
GET	/api/metodos-pago	Cualquier cuenta activa con rol vigente
POST	/api/metodos-pago	ROL_ADMIN
GET	/api/pagos	Cualquier cuenta activa con rol vigente
POST	/api/pagos	ROL_ADMIN, ROL_OPER
PUT	/api/pagos/{payment_id}	ROL_ADMIN, ROL_OPER
DELETE	/api/pagos/{payment_id}	ROL_ADMIN

Anexo B Trazabilidad detallada de controles

Las fichas siguientes completan la matriz de estado con ubicación, prueba, evidencia, residual y actividad pendiente. La amenaza y vulnerabilidad se resuelven por el identificador R de las matrices de riesgo, y los RS por el requisito académico. Todos los responsables son roles propuestos, sujetos a asignación. La fuente es controles.json; los estados se conservan sin elevarlos por la presentación de este documento.

C01 Las contraseñas usan PBKDF2-SHA256, salt aleatorio y comparación segura

Activo: A03. Riesgo: R02. Estado: Implementado y validado.

Implementación o ubicación: src/common/security.py.

Prueba requerida o ejecutada: test_password_salts_and_malformed_hashes; test_password_roundtrip. Evidencia: E01.

Riesgo residual y actividad pendiente: Validación local de funciones; rotación y política de longitud requieren revisión adicional. Responsable: Equipo técnico (propuesto); aprobación: propietaria por designar.

C02 El JWT requiere firma HS256, sub, jti, role, iat y exp válidos

Activo: A03. Riesgo: R01. Estado: Implementado y validado.

Implementación o ubicación: src/common/security.py.

Prueba requerida o ejecutada: test_invalid_tokens; test_required_claims; test_tampered_signature. Evidencia: E01.

Riesgo residual y actividad pendiente: No se prueba rotación de claves ni MFA; mantener secreto fuerte. Responsable: Equipo técnico (propuesto); aprobación: propietaria por designar.

C03 La revocación rechaza tokens cerrados y los fallos de Redis devuelven 503

Activo: A03. Riesgo: R01. Estado: Parcialmente implementado.

Implementación o ubicación: src/common/security.py.

Prueba requerida o ejecutada: test_logout_revokes_token; test_redis_failure_is_not_success. Evidencia: E01.

Riesgo residual y actividad pendiente: Probar API con Redis real, reinicio, persistencia y alertas; denegación temporal reduce disponibilidad. Responsable: Equipo técnico (propuesto); aprobación: propietaria por designar.

C04 La sesión protegida exige cuenta activa y rol vigente en PostgreSQL

Activo: A03. Riesgo: R03. Estado: Parcialmente implementado.

Implementación o ubicación: src/common/security.py.

Prueba requerida o ejecutada: test_user_removed_disabled_or_role_changed; test_database_unavailable. Evidencia: E01.

Riesgo residual y actividad pendiente: Identidad simulada en estas pruebas; integrar con BD real y medir latencia del nuevo SELECT. Responsable: Equipo técnico (propuesto); aprobación: propietaria por designar.

C05 Las rutas sensibles rechazan token ausente y rol insuficiente

Activo: A04. Riesgo: R03. Estado: Parcialmente implementado.

Implementación o ubicación: src/*/main.py; matriz-accesos.md.

Prueba requerida o ejecutada: test_missing_token_all_services; test_role_denied. Evidencia: E01.

Riesgo residual y actividad pendiente: Ampliar pruebas positivas/negativas a cada ruta y aprobar permisos de consulta con clínica. Responsable: Equipo técnico (propuesto); aprobación: propietaria por designar.

C06 Los datos de API insertados en HTML se codifican antes de mostrarse

Activo: A05. Riesgo: R04. Estado: Parcialmente implementado.

Implementación o ubicación: src/web/app.js; src/web/edit-modal.js.

Prueba requerida o ejecutada: node tests/security_frontend.cjs. Evidencia: E02.

Riesgo residual y actividad pendiente: Prueba de funciones y revisión de sinks; falta flujo XSS completo en navegador; JWT sigue en localStorage. Responsable: Equipo técnico (propuesto); aprobación: propietaria por designar.

C07 La entrada inválida se rechaza por esquema antes de registrar operaciones

Activo: A04. Riesgo: R05. Estado: Parcialmente implementado.

Implementación o ubicación: src/*/main.py.

Prueba requerida o ejecutada: test_invalid_payment_input; test_login. Evidencia: E01.

Riesgo residual y actividad pendiente: Añadir límites a listas/textos sin límite requiere autorización de contrato API. Responsable: Equipo técnico (propuesto); aprobación: propietaria por designar.

C08 El login parametriza SQL y no interpola el correo recibido

Activo: A04. Riesgo: R06. Estado: Implementado y validado.

Implementación o ubicación: src/auth/main.py; src/common/db.py.

Prueba requerida o ejecutada: test_parameterized_login_injection. Evidencia: E01.

Riesgo residual y actividad pendiente: Prueba limitada al login; actualizaciones dinámicas usan nombres de una lista fija, revisar cada cambio. Responsable: Equipo técnico (propuesto); aprobación: propietaria por designar.

C09 Inventario impide stock negativo y modificar movimientos históricos

Activo: A02. Riesgo: R05. Estado: Implementado y validado.

Implementación o ubicación: docker/postgres/init/001_schema.sql.

Prueba requerida o ejecutada: test_database_constraints_and_immutable_inventory; test_concurrent_inventory_no_negative_stock. Evidencia: E03.

Riesgo residual y actividad pendiente: Ensayo sintético de dos clientes, no prueba de carga sostenida ni de privilegios DBA. Responsable: Equipo técnico (propuesto); aprobación: propietaria por designar.

C10 Pagos concurrentes evitan sobrepago y revierten pago si falla confirmación

Activo: A02. Riesgo: R05. Estado: Implementado y validado.

Implementación o ubicación: docker/postgres/init/002_app_extensions.sql.

Prueba requerida o ejecutada: test_concurrent_payments_and_rollback; test_payment_failed_confirmation_rolls_back. Evidencia: E03.

Riesgo residual y actividad pendiente: Faltan combinaciones de editar/anular/descontar y todos los flujos de servicios realizados. Responsable: Equipo técnico (propuesto); aprobación: propietaria por designar.

C11 Un dump sintético restaura tablas, totales, stock y trigger de inmutabilidad

Activo: A02. Riesgo: R10. Estado: Implementado y validado.

Implementación o ubicación: tests/test_audit_database.py.

Prueba requerida o ejecutada: test_backup_restore_in_separate_database. Evidencia: E03.

Riesgo residual y actividad pendiente: Dump en memoria dentro del laboratorio; no acredita backup operativo cifrado, offsite ni recuperación completa del servicio. Responsable: Equipo técnico (propuesto); aprobación: propietaria por designar.

C12 El formulario de acceso no contiene credenciales precargadas

Activo: A05. Riesgo: R02. Estado: Implementado y validado.

Implementación o ubicación: src/web/index.html.

Prueba requerida o ejecutada: Inspección HTML y captura del formulario vacío. Evidencia: E04.

Riesgo residual y actividad pendiente: La cuenta académica sigue en SQL/README y debe rotarse antes de uso real. Responsable: Equipo técnico (propuesto); aprobación: propietaria por designar.

C13 La clínica aprueba identidades, altas, bajas, revisión de accesos y mínimo privilegio

Activo: A01. Riesgo: R03. Estado: Propuesto.

Implementación o ubicación: matriz-accesos.md; politica-seguridad.md.

Prueba requerida o ejecutada: Entrevista y revisión firmada de matriz. Evidencia: Sin evidencia operativa.

Riesgo residual y actividad pendiente: Faltan nombres, suplencias, lugar de acceso, aprobación y periodicidad aceptada. Responsable: Equipo técnico (propuesto); aprobación: propietaria por designar.

C14 Los eventos críticos conservan actor/resultado sin secretos ni datos excesivos

Activo: A02. Riesgo: R06. Estado: Parcialmente implementado.

Implementación o ubicación: SQL usuario/movimientos/pagos; gestion-incidentes.md.

Prueba requerida o ejecutada: Revisión de columnas de trazabilidad; ensayo de inventario. Evidencia: E03.

Riesgo residual y actividad pendiente: No hay auditoría central completa de login/cambios de privilegio ni retención aprobada. Responsable: Equipo técnico (propuesto); aprobación: propietaria por designar.

C15 Los errores al cliente no revelan SQL, infraestructura ni datos sensibles

Activo: A04. Riesgo: R06. Estado: Parcialmente implementado.

Implementación o ubicación: src/common/security.py; src/catalogo/main.py; src/pedidos/main.py; src/pagos/main.py.

Prueba requerida o ejecutada: 503 genérico en test_database_unavailable. Evidencia: E01.

Riesgo residual y actividad pendiente: Varios 409 aún muestran str(exc); sanear cambia contrato API y requiere autorización. Responsable: Equipo técnico (propuesto); aprobación: propietaria por designar.

C16 Aplicaciones usan rol PostgreSQL distinto de administración con permisos mínimos

Activo: A02. Riesgo: R03. Estado: Propuesto.

Implementación o ubicación: docker-compose.yml (configuración actual); plan-pruebas.md.

Prueba requerida o ejecutada: Comprobar privilegios efectivos y rechazo de DDL. Evidencia: Sin evidencia operativa.

Riesgo residual y actividad pendiente: Cuenta POSTGRES_USER compartida; diseñar migración/rol sin tocar persistencia existente. Responsable: Equipo técnico (propuesto); aprobación: propietaria por designar.

C17 Solo se exponen puertos justificados con límites de confianza y firewall

Activo: A06. Riesgo: R07. Estado: Parcialmente implementado.

Implementación o ubicación: docker-compose.yml; diagramas/despliegue.puml.

Prueba requerida o ejecutada: docker compose config --quiet e inspección. Evidencia: E05.

Riesgo residual y actividad pendiente: Compose publica APIs/BD/Redis en todas las interfaces; restringir exposición requiere validar entorno. Responsable: Equipo técnico (propuesto); aprobación: propietaria por designar.

C18 Los servidores y contenedores operan con mínimo privilegio y servicios necesarios

Activo: A06. Riesgo: R07. Estado: Parcialmente implementado.

Implementación o ubicación: docker/*/Dockerfile.

Prueba requerida o ejecutada: Build auth y ejecución UID 65532 con red none/read-only/cap-drop. Evidencia: E06.

Riesgo residual y actividad pendiente: Solo imagen auth ejecutada; flags endurecidos son ensayo, no configuración de Compose; web sigue con privilegios iniciales de nginx. Responsable: Equipo técnico (propuesto); aprobación: propietaria por designar.

C19 Se revisan parches, imágenes, EDR y bloqueo de equipos reales

Activo: A06. Riesgo: R08. Estado: Propuesto.

Implementación o ubicación: politica-seguridad.md.

Prueba requerida o ejecutada: Inventario de host, parches y escaneo de imágenes. Evidencia: Sin evidencia operativa.

Riesgo residual y actividad pendiente: Faltan acceso e inventario de dispositivos de clínica; no se instala EDR/IDS sin contexto. Responsable: Equipo técnico (propuesto); aprobación: propietaria por designar.

C20 El tráfico público y datos almacenados tienen protección de cifrado verificada

Activo: A01. Riesgo: R07. Estado: Propuesto.

Implementación o ubicación: proveedores-cloud.md.

Prueba requerida o ejecutada: Validar TLS público, certificados y cifrado de backup/BD. Evidencia: Sin evidencia operativa.

Riesgo residual y actividad pendiente: Solo HTTP local observado; no se acredita HTTPS público ni cifrado en reposo. Responsable: Equipo técnico (propuesto); aprobación: propietaria por designar.

C21 Los secretos se separan por ambiente y no se divulgan en evidencias

Activo: A03. Riesgo: R02. Estado: Parcialmente implementado.

Implementación o ubicación: .gitignore; .dockerignore; common/config.py.

Prueba requerida o ejecutada: Inspección de salidas y escaneo local de patrones. Evidencia: E07.

Riesgo residual y actividad pendiente: Persisten fallbacks conocidos y bootstrap; no equivale a inspección del historial ni rotación externa. Responsable: Equipo técnico (propuesto); aprobación: propietaria por designar.

C22 Los avisos de dependencias generan reporte y bloquean promoción

Activo: A08. Riesgo: R08. Estado: Parcialmente implementado.

Implementación o ubicación: requirements-security.txt; .github/workflows/security.yml.

Prueba requerida o ejecutada: pip-audit; análisis de duplicados/aplicabilidad. Evidencia: E08.

Riesgo residual y actividad pendiente: Avisos abiertos; workflow no ejecutado en GitHub; actualizar FastAPI/PyJWT requiere validación de compatibilidad. Responsable: Equipo técnico (propuesto); aprobación: propietaria por designar.

C23 Los hallazgos de análisis estático se revisan y trazan

Activo: A04. Riesgo: R06. Estado: Parcialmente implementado.

Implementación o ubicación: .github/workflows/security.yml; requisitos actuales.

Prueba requerida o ejecutada: bandit -r src -f json. Evidencia: E09.

Riesgo residual y actividad pendiente: B105 literal bearer no es credencial; B608 nombres de lista fija, revisar parámetros; no prueba ausencia de vulnerabilidades. Responsable: Equipo técnico (propuesto); aprobación: propietaria por designar.

C24 Una etapa requerida de deploy/post-deploy no termina bien si falta configuración

Activo: A07. Riesgo: R09. Estado: Parcialmente implementado.

Implementación o ubicación: .github/workflows/ci.yml; Jenkinsfile.

Prueba requerida o ejecutada: Revisión YAML: exit 1 ante secretos ausentes. Evidencia: E10/E11.

Riesgo residual y actividad pendiente: Corrida histórica #55 éxito con deploy/post-deploy omitidos según logs; falta ejecutar cambios nuevos en GitHub/Jenkins. Responsable: Equipo técnico (propuesto); aprobación: propietaria por designar.

C25 Repositorio exige revisiones, protección de ramas y permisos mínimos

Activo: A07. Riesgo: R09. Estado: Propuesto.

Implementación o ubicación: gestion-cambios.md.

Prueba requerida o ejecutada: Revisar branch rules, colaboradores y MFA. Evidencia: E11.

Riesgo residual y actividad pendiente: GitHub GET confirma main sin protección y rulesets vacíos; habilitar requiere autorización externa; MFA/colaboradores no revisados. Responsable: Equipo técnico (propuesto); aprobación: propietaria por designar.

C26 Los ambientes, secretos y datos de prueba permanecen separados

Activo: A07. Riesgo: R09. Estado: Parcialmente implementado.

Implementación o ubicación: scripts/collect_security_evidence.py; tests/test_audit_database.py.

Prueba requerida o ejecutada: Verificar etiqueta, nombre, red none, ausencia de bind mounts. Evidencia: E03.

Riesgo residual y actividad pendiente: Aislamiento local validado por fixture; separación cloud/staging por verificar. Responsable: Equipo técnico (propuesto); aprobación: propietaria por designar.

C27 Respaldos tienen responsable, frecuencia, retención y RTO/RPO aprobados

Activo: A02. Riesgo: R10. Estado: Propuesto.

Implementación o ubicación: respaldos-recuperacion.md.

Prueba requerida o ejecutada: Aprobación de BIA y simulacro de recuperación de servicio. Evidencia: Sin evidencia operativa.

Riesgo residual y actividad pendiente: Ensayo C11 no sustituye decisiones ni copias periódicas; sin RTO/RPO inventados. Responsable: Equipo técnico (propuesto); aprobación: propietaria por designar.

C28 Los incidentes siguen reporte, clasificación, contención, recuperación y revisión

Activo: A01. Riesgo: R11. Estado: Propuesto.

Implementación o ubicación: gestion-incidentes.md.

Prueba requerida o ejecutada: Ejercicio de mesa y registro firmado. Evidencia: Sin evidencia operativa.

Riesgo residual y actividad pendiente: Falta responsables/canal y simulacro con clínica. Responsable: Equipo técnico (propuesto); aprobación: propietaria por designar.

C29 Todo cambio relevante registra motivo, actor, alcance, impacto, pruebas y revisión

Activo: A07. Riesgo: R09. Estado: Parcialmente implementado.

Implementación o ubicación: gestion-cambios.md; evidencias/ejecuciones.json.

Prueba requerida o ejecutada: Revisión de diff, hashes y resultados locales. Evidencia: E01.

Riesgo residual y actividad pendiente: Cambios sin commit y sin revisión independiente; no simular aprobación. Responsable: Equipo técnico (propuesto); aprobación: propietaria por designar.

C30 Cada tercero registra datos, accesos, dependencia, riesgo y recuperación

Activo: A09. Riesgo: R12. Estado: Propuesto.

Implementación o ubicación: proveedores-cloud.md.

Prueba requerida o ejecutada: Confirmar contratos/cuentas y propietario por proveedor. Evidencia: Sin evidencia operativa.

Riesgo residual y actividad pendiente: Railway/Neon/Upstash referenciados; AWS previsto; ninguno acreditado operativo en esta auditoría. Responsable: Equipo técnico (propuesto); aprobación: propietaria por designar.

C31 Cloud documenta responsabilidad compartida, IAM/MFA/red/logs/alertas

Activo: A09. Riesgo: R12. Estado: Propuesto.

Implementación o ubicación: proveedores-cloud.md.

Prueba requerida o ejecutada: Inspección autorizada de recursos y permisos efectivos. Evidencia: Sin evidencia operativa.

Riesgo residual y actividad pendiente: Falta acceso a consolas y confirmación de servicios usados. Responsable: Equipo técnico (propuesto); aprobación: propietaria por designar.

C32 La política general define objetivo, alcance, principios, marco y aplicabilidad

Activo: A01. Riesgo: R11. Estado: Propuesto.

Implementación o ubicación: politica-seguridad.md.

Prueba requerida o ejecutada: Revisión y aprobación formal de documento. Evidencia: Sin evidencia operativa.

Riesgo residual y actividad pendiente: Borrador NIST CSF 2.0, sin adopción aprobada ni certificación. Responsable: Equipo técnico (propuesto); aprobación: propietaria por designar.

C33 Gobierno asigna propietarios de riesgos, autoridades y revisión

Activo: A01. Riesgo: R11. Estado: Propuesto.

Implementación o ubicación: politica-seguridad.md.

Prueba requerida o ejecutada: Acta de designaciones y aceptación de riesgos. Evidencia: Sin evidencia operativa.

Riesgo residual y actividad pendiente: Roles propuestos; no nombres ni aprobaciones ficticias. Responsable: Equipo técnico (propuesto); aprobación: propietaria por designar.

C34 Activos tienen inventario, propietario, clasificación, criticidad y manejo

Activo: A01. Riesgo: R11. Estado: Parcialmente implementado.

Implementación o ubicación: inventario-activos.md.

Prueba requerida o ejecutada: Contraste técnico con repositorio y entrevista. Evidencia: E10.

Riesgo residual y actividad pendiente: Inventario lógico del código; falta levantamiento físico y dueños de clínica. Responsable: Equipo técnico (propuesto); aprobación: propietaria por designar.

C35 Datos se clasifican y se decide retención, transferencia y eliminación

Activo: A01. Riesgo: R11. Estado: Propuesto.

Implementación o ubicación: politica-seguridad.md.

Prueba requerida o ejecutada: Aprobar tabla de tratamiento y plazos. Evidencia: Sin evidencia operativa.

Riesgo residual y actividad pendiente: No inferir obligaciones legales ni plazos de conservación médica. Responsable: Equipo técnico (propuesto); aprobación: propietaria por designar.

C36 Riesgos vinculan activo, amenaza, vulnerabilidad, P/I, tratamiento y residual

Activo: A01. Riesgo: R11. Estado: Parcialmente implementado.

Implementación o ubicación: matriz-riesgos.md.

Prueba requerida o ejecutada: Revisión técnica y validación por propietario. Evidencia: E10.

Riesgo residual y actividad pendiente: Puntuaciones preliminares del equipo, no decisiones aceptadas por la clínica. Responsable: Equipo técnico (propuesto); aprobación: propietaria por designar.

C37 Casos de uso, componentes, despliegue y secuencia incorporan controles trazables

Activo: A04. Riesgo: R11. Estado: Parcialmente implementado.

Implementación o ubicación: diagramas/*.puml; docs/ARCHITECTURE.md.

Prueba requerida o ejecutada: Contraste con rutas, Compose y common.security. Evidencia: E10.

Riesgo residual y actividad pendiente: Fuentes UML sin render PlantUML ni validación docente; no sustituyen implementación. Responsable: Equipo técnico (propuesto); aprobación: propietaria por designar.

C38 La red física, Wi-Fi/VPN/administración remota y monitoreo se verifican si aplican

Activo: A06. Riesgo: R07. Estado: Propuesto.

Implementación o ubicación: politica-seguridad.md; proveedores-cloud.md.

Prueba requerida o ejecutada: Entrevista y revisión de topología/reglas reales. Evidencia: Sin evidencia operativa.

Riesgo residual y actividad pendiente: Sin inventario real no se inventan VLAN, VPN, IDS/IPS ni firewall instalado. Responsable: Equipo técnico (propuesto); aprobación: propietaria por designar.

C39 Excepciones, terceros, uso de IA y mejora continua tienen revisión

Activo: A01. Riesgo: R11. Estado: Propuesto.

Implementación o ubicación: politica-seguridad.md.

Prueba requerida o ejecutada: Revisión periódica y registro de excepción con vencimiento. Evidencia: Sin evidencia operativa.

Riesgo residual y actividad pendiente: Falta aceptación formal y evaluación legal específica. Responsable: Equipo técnico (propuesto); aprobación: propietaria por designar.

C40 Las evidencias registran entorno, fecha, commit, procedimiento, resultado y límites

Activo: A07. Riesgo: R09. Estado: Implementado y validado.

Implementación o ubicación: evidencias/README.md; evidencias/ejecuciones.json.

Prueba requerida o ejecutada: Hashes y revisión de artefactos. Evidencia: E07.

Riesgo residual y actividad pendiente: Commit base más hashes de fuentes modificadas; evidencia local no equivale a validación en clínica. Responsable: Equipo técnico (propuesto); aprobación: propietaria por designar.

Anexo C Catálogo de evidencias y procedencia

Las rutas de esta sección se interpretan respecto de docs/seguridad/. El commit base es f5351224bd8910be20e19db743f6a7b1b7921401 y el código probado contiene cambios locales sin

commit; ejecuciones.json conserva sus hashes. Los metadatos y las fechas originales delimitan cada prueba. Una hora de conservación de archivo no se utiliza como inicio inferido de ejecución.

E01 Registro de evidencia

Control: C01–C05,C07–C10,C29. Riesgo: R01,R03,R05,R06.

Archivos (rutas relativas a esta carpeta): devsecops/final.xml; devsecops/final.html; devsecops/final.txt; devsecops/pytest-local.png.

Procedimiento: python scripts/collect_security_evidence.py --database.

Esperado: Sin fallos; omisiones externas explícitas.

Real: 69 aprobadas, 6 omitidas, 0 fallos; 1 warning de deprecación.

Estado: Implementado y validado solo ejecución local.

Límites: API con Redis/BD simulados; SQL con PostgreSQL real; no staging.

Commit/ambiente: los indicados al inicio; fecha/hora de conservación por archivo en MANIFEST-SHA256.json.

E02 Registro de evidencia

Control: C06. Riesgo: R04.

Archivos (rutas relativas a esta carpeta): autenticacion/frontend.txt.

Procedimiento: node tests/security_frontend.cjs.

Esperado: Etiquetas/comillas no inyectan HTML; formato conservado.

Real: PASS: texto, columnas, formato e identificadores sintéticos.

Estado: Parcialmente implementado.

Límites: Prueba de funciones JS en Node; no ataque DOM completo en navegador.

Commit/ambiente: los indicados al inicio; fecha/hora de conservación por archivo en MANIFEST-SHA256.json.

E03 Registro de evidencia

Control: C09–C11,C14,C26. Riesgo: R05,R10.

Archivos (rutas relativas a esta carpeta): bases-datos/postgres.xml; bases-datos/postgres.html; bases-datos/postgres.txt; bases-datos/postgres.png; bases-datos/version.txt; devsecops/final.xml.

Procedimiento: pytest tests/test_audit_database.py (AUDIT_DB_CONTAINER validado); pg_dump/psql dentro del contenedor.

Esperado: Sin stock negativo/sobrepago; rollback; restauración íntegra.

Real: 5 casos SQL aprobados en corrida separada y repetidos en final; PostgreSQL 16.15.

Estado: Implementado y validado en laboratorio.

Límites: Datos sintéticos; restauración de esquema, no servicio completo; no RTO/RPO de negocio.

Commit/ambiente: los indicados al inicio; fecha/hora de conservación por archivo en MANIFEST-SHA256.json.

E04 Registro de evidencia

Control: C12. Riesgo: R02.

Archivos (rutas relativas a esta carpeta): autenticacion/login-local.png; devsecops/configuracion.json.

Procedimiento: HTTP server 127.0.0.1:8766, abrir src/web/index.html con navegador y capturar.

Esperado: Correo/contraseña vacíos sin datos personales.

Real: Formulario sin valores precargados confirmado por AX y PNG.

Estado: Implementado y validado para formulario.

Límites: Servidor estático local sin backend; no es prueba de login desplegado.

Commit/ambiente: los indicados al inicio; fecha/hora de conservación por archivo en MANIFEST-SHA256.json.

E05 Registro de evidencia

Control: C17. Riesgo: R07.

Archivos (rutas relativas a esta carpeta): infraestructura/compose.txt; devsecops/configuracion.json.

Procedimiento: docker compose config --quiet; python scripts/inspect_security_config.py.

Esperado: Compose válido; enumerar exposición sin imprimir secretos.

Real: Salida válida; puertos 5432/6379/8001–8004/8080 expuestos en host.

Estado: Parcialmente implementado.

Límites: Valida sintaxis e inspección, no firewall/red productiva.

Commit/ambiente: los indicados al inicio; fecha/hora de conservación por archivo en MANIFEST-SHA256.json.

E06 Registro de evidencia

Control: C18. Riesgo: R07.

Archivos (rutas relativas a esta carpeta): contenedores/build-auth.txt; contenedores/runtime-auth.txt.

Procedimiento: construcción e importación de auth en contenedor aislado; comando exacto en evidencias/README.md y contenedores/build-auth.txt.

Esperado: Build e importación como usuario no root.

Real: Build exitoso; uid=65532; auth_import=ok.

Estado: Parcialmente implementado.

Límites: Solo imagen auth; flags de ensayo no aplicados a Compose; no escaneo CVE de imagen.

Commit/ambiente: los indicados al inicio; fecha/hora de conservación por archivo en MANIFEST-SHA256.json.

E07 Registro de evidencia

Control: C21,C40. Riesgo: R02,R09.

Archivos (rutas relativas a esta carpeta): revision-secretos.json; ejecuciones.json; MANIFEST-SHA256.json.

Procedimiento: Revisión de patrones sobre evidencias; hashes SHA256.

Esperado: Sin JWT, claves privadas ni contraseñas en evidencias.

Real: Resultado exacto en revision-secretos.json.

Estado: Implementado y validado para paquete local.

Límites: Escaneo por patrones y revisión visual; no historial Git ni certificación de ausencia total de secretos.

Commit/ambiente: los indicados al inicio; fecha/hora de conservación por archivo en MANIFEST-SHA256.json.

E08 Registro de evidencia

Control: C22. Riesgo: R08.

Archivos (rutas relativas a esta carpeta): vulnerabilidades/dependencias.json; vulnerabilidades/dependencias-runtime-dev.json.

Procedimiento: python -m pip_audit --format json --output <reporte> --progress-spinner off.

Esperado: Generar avisos y retornar no-cero si existen.

Real: Exit 1: 50 registros de avisos en 4 paquetes; 31 IDs distintos, algunos avisos tienen alias/duplicados.

Estado: Parcialmente implementado.

Límites: Paquetes instalados en .venv Windows; no acredita explotabilidad ni cubre SO/imagen Linux.

Commit/ambiente: los indicados al inicio; fecha/hora de conservación por archivo en MANIFEST-SHA256.json.

E09 Registro de evidencia

Control: C23. Riesgo: R06.

Archivos (rutas relativas a esta carpeta): vulnerabilidades/bandit.json.

Procedimiento: python -m bandit -r src -f json -o <reporte>.

Esperado: Análisis estático con hallazgos revisados.

Real: B105 bajo: literal bearer; B608 medio: UPDATE con nombres de lista fija.

Estado: Parcialmente implementado.

Límites: Bandit no sustituye revisión de código ni pruebas; no se suprimieron hallazgos sin explicación.

Commit/ambiente: los indicados al inicio; fecha/hora de conservación por archivo en MANIFEST-SHA256.json.

E10 Registro de evidencia

Control: C24,C34,C36,C37. Riesgo: R09,R11.

Archivos (rutas relativas a esta carpeta): devsecops/configuracion.json.

Procedimiento: python scripts/inspect_security_config.py y contraste con fuentes versionadas.

Esperado: Guardas exit 1 y permisos mínimos; topología coherente.

Real: Guardas locales de deploy/post-deploy devuelven exit 1 en configuración; inventario y UML contrastados.

Estado: Parcialmente implementado.

Límites: Sin ejecución nueva del cambio local; estado remoto/histórico verificado posteriormente en E11; UML fuente sin render.

Commit/ambiente: los indicados al inicio; fecha/hora de conservación por archivo en MANIFEST-SHA256.json.

E11 Registro de evidencia

Control: C24/C25; riesgos R09/R12; activo A07.

Evidencia: devsecops/github-historico.json.

Procedimiento: GitHub conector GET rama main, rulesets, runs del commit base, jobs y logs de tres jobs. Solo se conservan metadatos mínimos y líneas relevantes sin echo de comandos.

Fecha de consulta: consulta_utc dentro del JSON. Fecha de corrida: 10/10/2026; ambiente: GitHub Actions histórico, no ejecución local nueva. Commit: f5351224bd8910be20e19db743f6a7b1b7921401.

Esperado: determinar protección real y si éxito de job acredita deploy.

Real: main sin protección/rulesets vacíos; corrida #55 exitosa pero logs confirman despliegue y pruebas posteriores omitidos; 33 pruebas históricas aprobadas.

Estado: Parcialmente implementado (C24); Propuesto (C25).

Limitaciones: extractos sanitizados, sin cambios remotos, sin ejecutar workflows nuevos; permisos/MFA de cuentas no auditados.

Anexo D Casos de prueba ejecutados y omitidos

La lista siguiente reproduce el identificador de cada caso del XML final y su resultado. No incluye contraseñas ni JWT. El archivo final.xml es la fuente para las 75 entradas; la columna de origen permite distinguir SQL real, seguridad local, contrato o prueba externa omitida.

Tabla 23. Casos registrados en JUnit final

Identificador de prueba	Alcance	Resultado
test_database_constraints_and_immutable_inventory	SQL real	Aprobado
test_concurrent_inventory_no_negative_stock	SQL real	Aprobado
test_concurrent_payments_and_rollback	SQL real	Aprobado
test_payment_failed_confirmation_rolls_back	SQL real	Aprobado
test_backup_restore_in_separate_database	SQL real	Aprobado
test_password_salts_and_malformed_hashes	API con dobles / local	Aprobado
test_missing_token_all_services[app0-/api/users]	API con dobles / local	Aprobado
test_missing_token_all_services[app1-/api/catalogo/patients]	API con dobles / local	Aprobado
test_missing_token_all_services[app2-/api/pedidos]	API con dobles / local	Aprobado
test_missing_token_all_services[app3-/api/pagos]	API con dobles / local	Aprobado
test_invalid_tokens[expired]	API con dobles / local	Aprobado
test_invalid_tokens[empty-role]	API con dobles / local	Aprobado
test_invalid_tokens[invalid-jti]	API con dobles / local	Aprobado
test_invalid_tokens[string-exp]	API con dobles / local	Aprobado
test_invalid_tokens[boolean-iat]	API con dobles / local	Aprobado
test_invalid_tokens[malformed]	API con dobles / local	Aprobado

Identificador de prueba	Alcance	Resultado
test_required_claims[sub]	API con dobles / local	Aprobado
test_required_claims[exp]	API con dobles / local	Aprobado
test_required_claims[iat]	API con dobles / local	Aprobado
test_required_claims[jti]	API con dobles / local	Aprobado
test_required_claims[role]	API con dobles / local	Aprobado
test_tampered_signature	API con dobles / local	Aprobado
test_logout_revokes_token	API con dobles / local	Aprobado
test_redis_failure_is_not_success[get]	API con dobles / local	Aprobado
test_redis_failure_is_not_success[setex]	API con dobles / local	Aprobado
test_user_removed_disabled_or_role_changed[None]	API con dobles / local	Aprobado
test_user_removed_disabled_or_role_changed[record1]	API con dobles / local	Aprobado
test_user_removed_disabled_or_role_changed[record2]	API con dobles / local	Aprobado
test_database_unavailable	API con dobles / local	Aprobado
test_role_denied	API con dobles / local	Aprobado
test_login[valid]	API con dobles / local	Aprobado
test_login[wrong-password]	API con dobles / local	Aprobado
test_login[inactive]	API con dobles / local	Aprobado
test_parameterized_login_injection	API con dobles / local	Aprobado
test_invalid_payment_input	API con dobles / local	Aprobado
test_self_deactivation	API con dobles / local	Aprobado
test_compose_contains_required_services	Contrato / función local	Aprobado

Identificador de prueba	Alcance	Resultado
test_edit_handlers_open_form_instead_of_browser_prompt[editPatient-patients]	Contrato / función local	Aprobado
test_edit_handlers_open_form_instead_of_browser_prompt[editProduct-products]	Contrato / función local	Aprobado
test_edit_handlers_open_form_instead_of_browser_prompt[editService-services]	Contrato / función local	Aprobado
test_edit_handlers_open_form_instead_of_browser_prompt[editClinical-clinical]	Contrato / función local	Aprobado
test_edit_handlers_open_form_instead_of_browser_prompt[editOrder-orders]	Contrato / función local	Aprobado
test_edit_handlers_open_form_instead_of_browser_prompt[editPayment-payments]	Contrato / función local	Aprobado
test_edit_handlers_open_form_instead_of_browser_prompt[editUser-users]	Contrato / función local	Aprobado
test_edit_modal_loaded_into_deployed_nginx_image	Contrato / función local	Aprobado
test_unsaved_changes_require_explicit_discard	Contrato / función local	Aprobado
test_modal_uses_put_and_accessible_controls	Contrato / función local	Aprobado
test_responsive_modal_styles_present	Contrato / función local	Aprobado
test_javascript_syntax[app.js]	Contrato / función local	Aprobado
test_javascript_syntax[edit-modal.js]	Contrato / función local	Aprobado
test_staging_web_is_available	Externo no ejecutado	Omitido
test_auth_health_through_reverse_proxy	Externo no ejecutado	Omitido
test_protected_catalog_requires_authentication	Externo no ejecutado	Omitido
test_auth_health_average_response_under_two_seconds	Externo no ejecutado	Omitido
test_password_roundtrip	Contrato / función local	Aprobado
test_login_screen_and_navigation_with_chrome	Externo no ejecutado	Omitido
test_web_is_reachable	Externo no ejecutado	Omitido
test_patient_update_route_exists	Contrato / función local	Aprobado

Identificador de prueba	Alcance	Resultado
test_patient_soft_delete_route_exists	Contrato / función local	Aprobado
test_product_update_and_delete_routes_exist	Contrato / función local	Aprobado
test_service_update_and_delete_routes_exist	Contrato / función local	Aprobado
test_clinical_record_can_be_edited_before_close	Contrato / función local	Aprobado
test_clinical_record_uses_auditable_cancel	Contrato / función local	Aprobado
test_pending_order_has_update_route	Contrato / función local	Aprobado
test_order_delete_is_logical_cancel	Contrato / función local	Aprobado
test_order_cancel_annuls_registered_payments	Contrato / función local	Aprobado
test_payment_update_route_exists	Contrato / función local	Aprobado
test_payment_delete_is_logical_cancel	Contrato / función local	Aprobado
test_payment_edit_requires_pending_sale	Contrato / función local	Aprobado
test_admin_cannot_deactivate_self	Contrato / función local	Aprobado
test_frontend_exposes_edit_and_delete_actions	Contrato / función local	Aprobado
test_frontend_explains_inventory_auditability	Contrato / función local	Aprobado
test_new_visual_system_is_present	Contrato / función local	Aprobado
test_jenkinsfile_has_required_pipeline_stages	Contrato / función local	Aprobado
test_required_database_objects_exist	Contrato / función local	Aprobado

Anexo E Integridad del expediente y evidencia no reproducida

Los 34 archivos textuales revisados al cierre de la auditoría no presentaron coincidencias con los patrones sensibles comprobados. El análisis es limitado a patrones y revisión visual de PNG; no demuestra ausencia total de secretos ni cubre todo el historial Git. Los reportes pip-audit se sanitizaron para retirar ejemplos públicos de JWT en descripciones de avisos, conservando conteos e identificadores. Las fuentes y hashes de esa operación se registran en sanitizacion.json [E07; E08].

Se incorporaron las tres capturas PNG disponibles y las once categorías de evidencia mediante figuras, extractos o referencias. No se reproducen íntegros los reportes HTML/JSON/XML, el log de construcción o los manifiestos de hashes por extensión; se conservan en sus archivos originales con referencias precisas. No existen capturas nuevas de una ejecución real de Jenkins, Azure DevOps o staging. Las imágenes históricas del preliminar se conservan como antecedente en ese PDF y no se utilizan para validar el estado actual.

No se incluye un dump de base de datos, credenciales ni datos personales reales. No se publicaron los PDF de entrada. El laboratorio PostgreSQL y sus volúmenes temporales se retiraron después de conservar evidencias; la imagen local de auth se mantuvo sin publicar. Las carencias de captura no se sustituyen con imágenes generadas [evidencias/limpieza.md].

La aprobación de política, titulares y suplencias, inventario físico, matriz de acceso, clasificación y retención, objetivos de continuidad, proveedores y recursos externos permanecen pendientes. La presentación académica de este informe no modifica el estado real de estos requisitos ni constituye aceptación del riesgo por la clínica.